Jooby

```
┌──────────────────────────────────────────────────────────┐
│ 5 Reachable Supply Chain Findings │
└──────────────────────────────────────────────────────────┘
```

src/main/java/io/jooby/internal/netty/NettyContext.java with lockfile pom.xml
❯❯ io.netty:netty-common - CVE-2024-47535
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸┆ Fixed for io.netty:netty-common at version: 4.1.115.Final
714┆ listeners.run(this);

src/main/java/io/jooby/internal/netty/NettyPipeline.java with lockfile pom.xml
❯ io.netty:netty-codec-http - CVE-2025-58056
Severity: LOW
Affected versions of io.netty:netty-codec-http are vulnerable to Inconsistent Interpretation of HTTP
Requests ('HTTP Request/Response Smuggling'). Netty's HTTP chunked-encoding parser treats a lone LF
in a chunk extension as the end of the size line (instead of requiring CRLF per RFC 9112). If a
front-end proxy instead treats that LF as part of the extension, an attacker can craft a "funky
chunks" payload that the proxy sees as one request but Netty splits into two, enabling standard HTTP
request-smuggling attacks—bypassing access controls and corrupting responses to other clients.

▸▸┆ Fixed for io.netty:netty-codec-http at versions: 4.1.125.Final, 4.2.5.Final
119┆ return new HttpServerCodec(_4KB, _8KB, bufferSize, false);

src/main/java/io/jooby/internal/netty/NettyServerSentEmitter.java with lockfile pom.xml
❯❯ io.netty:netty-common - CVE-2024-47535
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸┆ Fixed for io.netty:netty-common at version: 4.1.115.Final

```
 85 ┆ closeTask.run();
```

src/main/java/io/jooby/internal/netty/NettyWebSocket.java with lockfile pom.xml

❯❯ io.netty:netty-common - CVE-2024-47535

Severity: MODERATE

Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

```
 ▸▸ ┆ Fixed for io.netty:netty-common at version: 4.1.115.Final
242 ┆ task.run();
  ⋮ ┆ ----------------------------------------
283 ┆ runnable.run();
```

5 Undetermined Supply Chain Findings

pom.xml

❯❯ io.netty:netty-codec - CVE-2025-58057

Severity: MODERATE

Affected versions of io.netty:netty-codec and io.netty:netty-codec-compression are vulnerable to

Improper Handling of Highly Compressed Data (Data Amplification).

```
 ▸▸ ┆ Fixed for io.netty:netty-codec at version: 4.1.125.Final
  1 ┆ <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec-http - CVE-2025-67735

Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Improper Neutralization of CRLF

Sequences ('CRLF Injection').

```
 ▸▸ ┆ Fixed for io.netty:netty-codec-http at versions: 4.1.129.Final, 4.2.8.Final
  1 ┆ <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec-http - CVE-2024-29025

Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Allocation of Resources Without

Limits or Throttling.

```
 ▸▸ ┆ Fixed for io.netty:netty-codec-http at version: 4.1.108.Final
```

1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-handler - CVE-2023-34462
Severity: MODERATE
Affected versions of io.netty:netty-handler are vulnerable to Allocation of Resources Without Limits
or Throttling / Uncontrolled Resource Consumption.

▸▸ ┆ Fixed for io.netty:netty-handler at version: 4.1.94.Final
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2025-25193
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ ┆ Fixed for io.netty:netty-common at version: 4.1.118.Final
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

┌──────────────┐
│ Scan Summary │
└──────────────┘

✅ CI scan completed successfully.
• Findings: 10 (0 blocking)
• Rules run: 115837
• Targets scanned: 31
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 5
  ◦ Files matching .semgrepignore patterns: 145
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/jooby&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/jooby&ref=semgrep-uc
No blocking findings so exiting with code 0

```
⏫ A new version of Semgrep is available. See https://semgrep.dev/docs/upgrading
yogyagamage@Yogyas-MacBook-Air jooby-netty % cd ../jooby-utow
yogyagamage@Yogyas-MacBook-Air jooby-utow % semgrep ci  --allow-local-builds
WARNING: `semgrep ci` is meant to be run from the root of a git repo.
When `semgrep ci` is not run from a git repo, it will not be able to perform all operations.
When `semgrep ci` is run from a git repo, but not the root, links in the uploaded findings may be
broken.

To run `semgrep ci` on only a subdirectory of a git repo, see `--subdir`.


┌──────────────────┐
│ Debugging Info │
└──────────────────┘

  SCAN ENVIRONMENT
  versions    - semgrep 1.153.0 on python 3.14.3
  environment - running in environment git, triggering event is unknown

  CONNECTION
  Initializing scan (deployment=tulipgamage-personal-org, scan_id=144564571)
  Enabled products: Code, Supply Chain


  ENGINE
  Using Semgrep Pro Version: 1.153.0
  Installed at
/opt/homebrew/Cellar/semgrep/1.153.0/libexec/lib/python3.14/site-packages/semgrep/bin/semgr
ep-core-propri

  Scanning 41 files (only git-tracked) with 2829 Code rules, 6307 Supply Chain rules:

  CODE RULES

  Language      Rules   Files         Origin      Rules
 ──────────────────────────────────────────────────────      ──────────────────────────────
  <multilang>      47      41         Pro rules    1765
  json              4      25         Community    1064
  java            296      12


  SUPPLY CHAIN RULES

  Dependency Sources   Resolution Method   Ecosystem   Dependencies   Rules
```

pom.xml Local build Maven 25 6307

Analysis Rules

Basic 5504
Reachability 803

PROGRESS

100% 0:00:00
Uploading scan results
Finalizing scan

┌──────────────────────────────────────┐
│ 8 Reachable Supply Chain Findings │
└──────────────────────────────────────┘

pom.xml
❯❯❯ io.undertow:undertow-core - CVE-2024-1635
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Uncontrolled Resource Consumption.
Under specific conditions during an HTTP upgrade to a remoting connection, Undertow fails to clean
up a timeout task when a connection is abruptly closed. This results in lingering references in the
worker thread, leading to both memory and file descriptor leaks that can exhaust server resources.
An attacker could repeatedly open and close connections to trigger resource exhaustion and
potentially cause a denial-of-service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.31.Final, 2.3.12.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2024-5971
Severity: HIGH

Affected versions of io.undertow:undertow-core are vulnerable to Uncontrolled Recursion. Undertow
does not send the expected `0 ` termination of the chunked response. This results in uncontrolled
resource consumption, leaving the server side to a denial of service attack. This happens only with
Java 17 TLSv1.3 scenarios.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.34.Final, 2.3.15.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ io.undertow:undertow-core - CVE-2025-12543
Severity: CRITICAL
Affected versions of io.undertow:undertow-core are vulnerable to Improper Input Validation. The
Undertow HTTP server core fails to properly validate incoming `Host` headers. An attacker who sends
malformed or arbitrary Host values can poison HTTP caches, probe or scan internal network services,
or hijack user sessions by exploiting Host-based routing or cookie binding.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.39.Final, 2.3.21.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2023-1108
Severity: HIGH
io.undertow:undertow-core versions before 2.3.5.Final are vulnerable to Denial-of-Service (DoS). An
attacker can exploit this attack because of an unexpected handshake status in `SslConduit`, causing
an endless loop.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.24.Final, 2.3.5.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2024-4027
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Allocation of Resources Without
Limits or Throttling. Attackers may exploit uncontrolled resource consumption to degrade performance
or cause service disruption.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.39.Final, 2.3.21.Final, 2.4.0.Beta1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2024-3884
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Improper Input Validation. When
Undertow parses large application/x-www-form-urlencoded bodies via
FormEncodedDataDefinition.doParse(StreamSourceChannel), it can allocate unbounded buffers and run
out of memory, allowing a remote attacker to trigger an OutOfMemoryError and cause a denial-of-
service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.39.Final, 2.3.21.Final, 2.4.0.Beta1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2024-6162
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Exposure of Data Element to Wrong
Session / Uncontrolled Resource Consumption. URL-encoded request path information can be broken for
concurrent requests on ajp-listener (Apache JServ Protocol), causing the wrong path to be processed
and resulting in a possible denial of service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.33.Final, 2.3.14.Final
1 <?xml version="1.0" encoding="UTF-8"?>

src/main/java/io/jooby/utow/Utow.java with lockfile pom.xml
❯❯❯ io.undertow:undertow-core - CVE-2023-4639
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Inconsistent Interpretation of HTTP
Requests ('HTTP Request/Response Smuggling'). A flaw was found in Undertow, which incorrectly parses
cookies with certain value-delimiting characters in incoming requests. This issue could allow an
attacker to construct a cookie value to exfiltrate HttpOnly cookie values or spoof arbitrary
additional cookie values, leading to unauthorized data access or modification.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.30.Final, 2.3.11.Final
146 server.start();

3 Undetermined Supply Chain Findings

pom.xml
❯❯ io.undertow:undertow-core - CVE-2023-1973
Severity: MODERATE
Affected versions of io.undertow:undertow-core are vulnerable to Improper Input Validation /
Uncontrolled Resource Consumption.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.32.Final, 2.3.13.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.undertow:undertow-core - CVE-2024-3653
Severity: MODERATE
Affected versions of io.undertow:undertow-core are vulnerable to Missing Release of Memory after
Effective Lifetime.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.34.Final, 2.3.15.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.undertow:undertow-core - CVE-2024-1459
Severity: MODERATE
Affected versions of io.undertow:undertow-core are vulnerable to Path Traversal.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.31.Final, 2.3.12.Final
1 <?xml version="1.0" encoding="UTF-8"?>

7 Unreachable Supply Chain Findings

pom.xml
❯❯❯ io.undertow:undertow-core - CVE-2023-4639
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Inconsistent Interpretation of HTTP

Requests ('HTTP Request/Response Smuggling'). A flaw was found in Undertow, which incorrectly parses
cookies with certain value-delimiting characters in incoming requests. This issue could allow an
attacker to construct a cookie value to exfiltrate HttpOnly cookie values or spoof arbitrary
additional cookie values, leading to unauthorized data access or modification.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.30.Final, 2.3.11.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2025-9784
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Allocation of Resources Without
Limits or Throttling / Improper Resource Shutdown or Release. Undertow's HTTP handling fails to
count malformed requests that trigger server-side stream resets against its abuse limits. A
malicious client can repeatedly send crafted requests that abort streams without bumping abuse
counters, forcing excessive server workload and resulting in a denial-of-service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.38.Final, 2.3.20.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ io.undertow:undertow-core - CVE-2022-4492
Severity: CRITICAL
io.undertow:undertow-core versions before 2.2.24.Final, >= 2.3.0 before 2.3.5.Final are vulnerable
to improper certificate validation. The undertow client does not check the server identity presented
by the server certificate in https connections.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.24.Final, 2.3.5.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2025-9784
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Allocation of Resources Without
Limits or Throttling / Improper Resource Shutdown or Release. Undertow's HTTP handling fails to
count malformed requests that trigger server-side stream resets against its abuse limits. A

malicious client can repeatedly send crafted requests that abort streams without bumping abuse
counters, forcing excessive server workload and resulting in a denial-of-service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.38.Final, 2.3.20.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.jboss.xnio:xnio-api - CVE-2023-5685
Severity: HIGH
Affected versions of org.jboss.xnio:xnio-api are vulnerable to Uncontrolled Resource Consumption.
The XNIO NotifierState can cause a Stack Overflow Exception when the chain of notifier states
becomes problematically large.

▸▸ Fixed for org.jboss.xnio:xnio-api at version: 3.8.14.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2024-7885
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Concurrent Execution using Shared
Resource with Improper Synchronization ('Race Condition'). The `ProxyProtocolReadListener` reuses
the same `StringBuilder` instance across multiple requests. This issue occurs when the
`parseProxyProtocolV1` method processes multiple requests on the same HTTP connection. As a result,
different requests may share the same `StringBuilder` instance, potentially leading to information
leakage between requests or responses.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.36.Final, 2.3.17.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.undertow:undertow-core - CVE-2025-9784
Severity: HIGH
Affected versions of io.undertow:undertow-core are vulnerable to Allocation of Resources Without
Limits or Throttling / Improper Resource Shutdown or Release. Undertow's HTTP handling fails to
count malformed requests that trigger server-side stream resets against its abuse limits. A
malicious client can repeatedly send crafted requests that abort streams without bumping abuse

counters, forcing excessive server workload and resulting in a denial-of-service.

▸▸ Fixed for io.undertow:undertow-core at versions: 2.2.38.Final, 2.3.20.Final
1 <?xml version="1.0" encoding="UTF-8"?>

```
┌──────────────────┐
│ Scan Summary │
└──────────────────┘
```

✅ CI scan completed successfully.
• Findings: 18 (0 blocking)
• Rules run: 115837
• Targets scanned: 41
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 3
  ◦ Files matching .semgrepignore patterns: 77
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/jooby&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/jooby&ref=semgrep-uc
  No blocking findings so exiting with code 0

```
┌──────────────────────────────────────┐
│ 1 Reachable Supply Chain Finding │
└──────────────────────────────────────┘
```

  src/main/java/io/jooby/jetty/Jetty.java with lockfile pom.xml
❯❯❱ org.eclipse.jetty:jetty-server - CVE-2024-13009
        Severity: HIGH
        Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Improper Resource Shutdown or
        Release. Eclipse Jetty improperly handles gzip decompression errors in request bodies, leading to an
        incorrect buffer release. This flaw can result in data corruption and unintended data sharing

between requests.

▸▸ Fixed for org.eclipse.jetty:jetty-server at version: 9.4.57.v20241219
211 server.start();

6 Undetermined Supply Chain Findings

pom.xml
❯❯ org.eclipse.jetty:jetty-server - CVE-2024-8184
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Allocation of Resources Without Limits or Throttling / Uncontrolled Resource Consumption.

▸▸ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.24, 11.0.24, 12.0.9, 9.4.56
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.eclipse.jetty:jetty-http - CVE-2024-6763
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Validation of Syntactic
Correctness of Input.

▸▸ Fixed for org.eclipse.jetty:jetty-http at version: 12.0.12
1 <?xml version="1.0" encoding="UTF-8"?>

❯ org.eclipse.jetty:jetty-server - CVE-2023-26049
Severity: LOW
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Exposure of Sensitive Information to an Unauthorized Actor.

▸▸ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.14, 11.0.14, 12.0.0.beta0, 9.4.51.v20230217
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.eclipse.jetty:jetty-http - CVE-2023-40167
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Handling of Length
Parameter Inconsistency.

▸▸ Fixed for org.eclipse.jetty:jetty-http at versions: 10.0.16, 11.0.16, 12.0.1, 9.4.52

1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.eclipse.jetty:jetty-server - CVE-2023-26048
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Allocation of Resources Without Limits or Throttling / Uncontrolled Resource Consumption.

▸▸ ┆ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.14, 11.0.14, 9.4.51.v20230217
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯ org.eclipse.jetty:jetty-http - CVE-2025-11143
Severity: LOW
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Input Validation.

▸▸ ┆ Fixed for org.eclipse.jetty:jetty-http at versions: 12.0.31, 12.1.5
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

```
┌──────────────┐
│ Scan Summary │
└──────────────┘
```

✅ CI scan completed successfully.
• Findings: 7 (0 blocking)
• Rules run: 115837
• Targets scanned: 25
• Parsed lines: ~100.0%
• Scan skipped:
◦ Files larger than files 1.0 MB: 4
◦ Files matching .semgrepignore patterns: 79
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/jooby&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/jooby&ref=semgrep-uc
No blocking findings so exiting with code 0

4 Reachable Supply Chain Findings

pom.xml

❯❯❯ org.eclipse.jetty.http2:http2-hpack - CVE-2023-36478

Severity: HIGH

Affected versions of org.eclipse.jetty.http3:http3-qpack, org.eclipse.jetty:jetty-http, and org.eclipse.jetty.http2:http2-hpack are vulnerable to Integer Overflow Or Wraparound. An attacker can exploit the integer overflow in `MetaDataBuilder.checkSize` to manipulate HTTP/2 HPACK header values, potentially causing buffer overflows and server memory exhaustion by sending crafted headers.

▸▸ Fixed for org.eclipse.jetty.http2:http2-hpack at versions: 10.0.16, 11.0.16, 9.4.53

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ org.eclipse.jetty.http2:http2-common - CVE-2025-5115

Severity: HIGH

Affected versions of org.eclipse.jetty.http2:http2-common and org.eclipse.jetty.http2:jetty-http2-common are vulnerable to Allocation of Resources Without Limits or Throttling / Uncontrolled Resource Consumption. A malicious HTTP/2 client can send malformed control frames (for example, WINDOW_UPDATE frames with a zero or overflow increment, HEADERS/DATA on half-closed streams, or mis-framed PRIORITY frames) to Eclipse Jetty's HTTP/2 server, triggering RST_STREAM responses that prematurely decrement the active-stream counter. This lets an attacker repeatedly open new streams on a single connection without ever hitting the max-concurrent-streams limit, exhausting CPU and/or memory and resulting in denial of service. This is a protocol level attack.

▸▸ Fixed for org.eclipse.jetty.http2:http2-common at versions: 10.0.26, 11.0.26, 9.4.58

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

src/main/java/io/jooby/internal/jetty/JettyHttp2Configurer.java with lockfile pom.xml

❯❯❯ org.eclipse.jetty.http2:http2-common - CVE-2025-5115

Severity: HIGH
Affected versions of org.eclipse.jetty.http2:http2-common and org.eclipse.jetty.http2:jetty-
http2-common are vulnerable to Allocation of Resources Without Limits or Throttling / Uncontrolled
Resource Consumption. A malicious HTTP/2 client can send malformed control frames (for example,
WINDOW_UPDATE frames with a zero or overflow increment, HEADERS/DATA on half-closed streams, or mis-
framed PRIORITY frames) to Eclipse Jetty's HTTP/2 server, triggering RST_STREAM responses that
prematurely decrement the active-stream counter. This lets an attacker repeatedly open new streams
on a single connection without ever hitting the max-concurrent-streams limit, exhausting CPU and/or
memory and resulting in denial of service. This is a protocol level attack.

```
▸▸ Fixed for org.eclipse.jetty.http2:http2-common at versions: 10.0.26, 11.0.26, 9.4.58
37 HTTP2ServerConnectionFactory https2 = new HTTP2ServerConnectionFactory(input);
⋮ ----------------------------------------
41 return Collections.singletonList(new HTTP2CServerConnectionFactory(input));
```

8 Undetermined Supply Chain Findings

pom.xml

❯❯ org.eclipse.jetty:jetty-server - CVE-2024-8184
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Allocation of Resources
Without Limits or Throttling / Uncontrolled Resource Consumption.

```
▸▸ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.24, 11.0.24, 12.0.9, 9.4.56
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ org.eclipse.jetty:jetty-http - CVE-2024-6763
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Validation of Syntactic
Correctness of Input.

```
▸▸ Fixed for org.eclipse.jetty:jetty-http at version: 12.0.12
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ org.eclipse.jetty.http2:http2-common - CVE-2023-44487
Severity: MODERATE
Affected versions of com.typesafe.akka:akka-http-core, com.typesafe.akka:akka-http-core_2.11,
com.typesafe.akka:akka-http-core_2.12, com.typesafe.akka:akka-http-core_2.13,
org.apache.tomcat.embed:tomcat-embed-core, org.apache.tomcat:tomcat-coyote,
org.eclipse.jetty.http2:http2-common, org.eclipse.jetty.http2:http2-server,
org.eclipse.jetty.http2:jetty-http2-common, and org.eclipse.jetty.http2:jetty-http2-server are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for org.eclipse.jetty.http2:http2-common at versions: 10.0.17, 11.0.17, 9.4.53
1 <?xml version="1.0" encoding="UTF-8"?>
⋮ ----------
1 <?xml version="1.0" encoding="UTF-8"?>

❯ org.eclipse.jetty:jetty-server - CVE-2023-26049
Severity: LOW
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Exposure of Sensitive Information to an Unauthorized Actor.

▸▸ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.14, 11.0.14, 12.0.0.beta0, 9.4.51.v20230217
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.eclipse.jetty:jetty-http - CVE-2023-40167
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Handling of Length
Parameter Inconsistency.

▸▸ Fixed for org.eclipse.jetty:jetty-http at versions: 10.0.16, 11.0.16, 12.0.1, 9.4.52
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.eclipse.jetty:jetty-server - CVE-2023-26048
Severity: MODERATE
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Allocation of Resources Without Limits or Throttling / Uncontrolled Resource Consumption.

▸▸ Fixed for org.eclipse.jetty:jetty-server at versions: 10.0.14, 11.0.14, 9.4.51.v20230217
1 <?xml version="1.0" encoding="UTF-8"?>

❯ org.eclipse.jetty:jetty-http - CVE-2025-11143

Severity: LOW
Affected versions of org.eclipse.jetty:jetty-http are vulnerable to Improper Input Validation.

▸▸ Fixed for org.eclipse.jetty:jetty-http at versions: 12.0.31, 12.1.5
1 <?xml version="1.0" encoding="UTF-8"?>

2 Unreachable Supply Chain Findings

pom.xml
❯❯❯ org.eclipse.jetty:jetty-server - CVE-2024-13009
Severity: HIGH
Affected versions of org.eclipse.jetty:jetty-server are vulnerable to Improper Resource Shutdown or
Release. Eclipse Jetty improperly handles gzip decompression errors in request bodies, leading to an
incorrect buffer release. This flaw can result in data corruption and unintended data sharing
between requests.

▸▸ Fixed for org.eclipse.jetty:jetty-server at version: 9.4.57.v20241219
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.eclipse.jetty.http2:http2-common - CVE-2024-22201
Severity: HIGH
Affected versions of org.eclipse.jetty.http3:jetty-http3-common, org.eclipse.jetty.http2:jetty-
http2-common, org.eclipse.jetty.http3:http3-common, and org.eclipse.jetty.http2:http2-common are
vulnerable to Uncontrolled Resource Consumption. The vulnerability stems from a flaw in managing
HTTP/2 and HTTP/3 connections where TCP congestion leads to idle timeouts, potentially resulting in
the connection staying open despite being marked as closed

▸▸ Fixed for org.eclipse.jetty.http2:http2-common at versions: 10.0.20, 11.0.20, 9.4.54
1 <?xml version="1.0" encoding="UTF-8"?>

Scan Summary

✅ CI scan completed successfully.
• Findings: 14 (0 blocking)
• Rules run: 115879
• Targets scanned: 25
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files matching .semgrepignore patterns: 5
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/jooby&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/jooby&ref=semgrep-uc
  No blocking findings so exiting with code 0

```
┌──────────────────────────────────────────┐
│ 3 Reachable Supply Chain Findings │
└──────────────────────────────────────────┘
```

  pom.xml
  ❯❯❱ io.netty:netty-codec-http2 - GHSA-xpw8-rcwv-8f8p
        Severity: HIGH
        Affected versions of io.netty:netty-codec-http2 are vulnerable to Uncontrolled Resource Consumption.
        The vulnerability arises when a client issues frequent `RST frames`, potentially leading to server
        overload and facilitating a DDoS attack by imposing a significant load on the remote system.

        ▸▸┆ Fixed for io.netty:netty-codec-http2 at version: 4.1.100.Final
        1┆ <?xml version="1.0" encoding="UTF-8"?>

  ❯❯❱ io.netty:netty-codec-http2 - CVE-2025-55163
        Severity: HIGH
        Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to

Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service. This is a protocol level attack.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>

src/main/java/io/jooby/internal/netty/NettyHttp2Configurer.java with lockfile pom.xml
❯❯❯ io.netty:netty-codec-http2 - CVE-2025-55163
Severity: HIGH
Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to
Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
57 return new HttpToHttp2ConnectionHandlerBuilder()

5 Undetermined Supply Chain Findings

pom.xml

❯❯ io.netty:netty-codec - CVE-2025-58057

Severity: MODERATE

Affected versions of io.netty:netty-codec and io.netty:netty-codec-compression are vulnerable to

Improper Handling of Highly Compressed Data (Data Amplification).

▸▸ Fixed for io.netty:netty-codec at version: 4.1.125.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec-http - CVE-2025-67735

Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Improper Neutralization of CRLF

Sequences ('CRLF Injection').

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.129.Final, 4.2.8.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec-http - CVE-2024-29025

Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Allocation of Resources Without

Limits or Throttling.

▸▸ Fixed for io.netty:netty-codec-http at version: 4.1.108.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-handler - CVE-2023-34462

Severity: MODERATE

Affected versions of io.netty:netty-handler are vulnerable to Allocation of Resources Without Limits

or Throttling / Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-handler at version: 4.1.94.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-common - CVE-2025-25193

Severity: MODERATE

Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.118.Final

1 <?xml version="1.0" encoding="UTF-8"?>

2 Unreachable Supply Chain Findings

pom.xml

❱ io.netty:netty-codec-http - CVE-2025-58056

Severity: LOW

Affected versions of io.netty:netty-codec-http are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling'). Netty's HTTP chunked-encoding parser treats a lone LF in a chunk extension as the end of the size line (instead of requiring CRLF per RFC 9112). If a front-end proxy instead treats that LF as part of the extension, an attacker can craft a "funky chunks" payload that the proxy sees as one request but Netty splits into two, enabling standard HTTP request-smuggling attacks—bypassing access controls and corrupting responses to other clients.

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.125.Final, 4.2.5.Final

1 <?xml version="1.0" encoding="UTF-8"?>

❱❱ io.netty:netty-common - CVE-2024-47535

Severity: MODERATE

Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.115.Final

1 <?xml version="1.0" encoding="UTF-8"?>

Scan Summary

✅ CI scan completed successfully.

- Findings: 10 (0 blocking)
- Rules run: 115879
- Targets scanned: 25
- Parsed lines: ~100.0%

• Scan skipped:
  ◦ Files matching .semgrepignore patterns: 2
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/jooby&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/jooby&ref=semgrep-uc
  No blocking findings so exiting with code 0

Flink

```
┌──────────────────────────────────────────┐
│ 6 Reachable Supply Chain Findings │
└──────────────────────────────────────────┘
```

  pom.xml
❯❯❱ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10172
    Severity: HIGH
    Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Improper Restriction
    Of Xml External Entity Reference. The primary threat from this flaw is data integrity. The repo was
    archived in Nov 2022 and is no longer supported. The recommendation is to remove Codehaus and update
    to FasterXML.

    ▸▸┆ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:
     1┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❱ io.netty:netty-codec-http2 - CVE-2025-55163
    Severity: HIGH
    Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to

Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service. This is a protocol level attack.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ net.minidev:json-smart - CVE-2021-27568
Severity: MODERATE
Affected versions of net.minidev:json-smart 2.3.x before 2.3.1, net.minidev:json-smart 2.4.x before
2.4.1, net.minidev:json-smart-mini 1.3.x before 1.3.2, and net.minidev:json-smart 1.3.x before 1.3.2
are vulnerable to Improper Check For Unusual Or Exceptional Conditions. The vulnerability arises
from an uncaught exception (e.g., NumberFormatException) thrown from a function, potentially causing
program crashes or sensitive information exposure, as the parser fails to generate a ParseException
when expecting float number input that is not valid, resulting in unhandled exceptions and potential
Denial-of-Service (DoS) scenarios due to unexpected input.

▸▸ Fixed for net.minidev:json-smart at versions: 1.3.2, 2.3.1, 2.4.1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.sun.jersey:jersey-core - CVE-2014-3643
Severity: HIGH
Affected versions of com.sun.jersey:jersey-core are vulnerable to Improper Restriction of XML
External Entity Reference. Jersey's built-in SAX XML parser does not disable parameter entity

processing, leaving any XML-consuming endpoint vulnerable to XXE. An attacker can submit crafted XML
with external parameter entities to read internal files or trigger server-side requests.

▸▸ Fixed for com.sun.jersey:jersey-core at version: 1.13
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.protobuf:protobuf-java - CVE-2021-22569
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java and com.google.protobuf:protobuf-kotlin are
vulnerable to Incorrect Behavior Order. Parsing of unknown fields in the Java Protobuf runtime can
be abused by a crafted binary payload (~800 KB) to trigger excessive short-lived object allocations,
causing repeated GC pauses and prolonged parsing times, resulting in a Denial of Service.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.1, 3.18.2, 3.19.2
1 <?xml version="1.0" encoding="UTF-8"?>

src/main/java/org/apache/flink/orc/writer/PhysicalWriterImpl.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
24 import com.google.protobuf.CodedOutputStream;

22 Undetermined Supply Chain Findings

pom.xml

❯❯ org.apache.zookeeper:zookeeper - CVE-2024-23944
Severity: MODERATE
Affected versions of org.apache.zookeeper:zookeeper are vulnerable to Exposure of Sensitive
Information to an Unauthorized Actor / Missing Authorization.

▸▸ Fixed for org.apache.zookeeper:zookeeper at versions: 3.8.4, 3.9.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ commons-net:commons-net - CVE-2021-37533
Severity: MODERATE
Affected versions of commons-net:commons-net are vulnerable to Improper Input Validation.

▸▸ Fixed for commons-net:commons-net at version: 3.9.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec - CVE-2025-58057
Severity: MODERATE
Affected versions of io.netty:netty-codec and io.netty:netty-codec-compression are vulnerable to
Improper Handling of Highly Compressed Data (Data Amplification).

▸▸ Fixed for io.netty:netty-codec at version: 4.1.125.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21409
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are
vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.apache.logging.log4j:log4j-core - CVE-2025-68161
Severity: MODERATE
Affected versions of org.apache.logging.log4j:log4j-core are vulnerable to Improper Validation of
Certificate with Host Mismatch.

▸▸ Fixed for org.apache.logging.log4j:log4j-core at version: 2.25.3
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ commons-lang:commons-lang - CVE-2025-48924
Severity: MODERATE
Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable to Uncontrolled Recursion.

```
▸▸ Fixed for commons-lang:commons-lang at version:
 1 <?xml version="1.0" encoding="UTF-8"?>
 ⋮ ----------------------------------------
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty - CVE-2019-20445
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-handler, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

```
▸▸ Fixed for io.netty:netty at version:
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec-http - CVE-2025-67735
Severity: MODERATE
Affected versions of io.netty:netty-codec-http are vulnerable to Improper Neutralization of CRLF Sequences ('CRLF Injection').

```
▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.129.Final, 4.2.8.Final
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ org.apache.hadoop:hadoop-common - CVE-2024-23454
Severity: LOW
Affected versions of org.apache.hadoop:hadoop-common are vulnerable to Creation of Temporary File With Insecure Permissions / Improper Privilege Management.

```
▸▸ Fixed for org.apache.hadoop:hadoop-common at version: 3.4.0
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty - CVE-2021-21290
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are vulnerable to Creation of Temporary File With Insecure Permissions / Creation of Temporary File in Directory with Insecure Permissions / Exposure of Resource to Wrong Sphere.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.google.protobuf:protobuf-java - CVE-2022-3171
Severity: MODERATE
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.3, 3.19.6, 3.20.3, 3.21.7
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21295
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are
vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.codehaus.jettison:jettison - CVE-2022-40149
Severity: MODERATE
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-of-bounds Write / Stack-
based Buffer Overflow.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec-http - CVE-2024-29025
Severity: MODERATE
Affected versions of io.netty:netty-codec-http are vulnerable to Allocation of Resources Without
Limits or Throttling.

▸▸ Fixed for io.netty:netty-codec-http at version: 4.1.108.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.squareup.okio:okio - CVE-2023-3635

Severity: MODERATE
Affected versions of com.squareup.okio:okio and com.squareup.okio:okio-jvm are vulnerable to
Incorrect Conversion between Numeric Types / Signed to Unsigned Conversion Error.

▸▸ Fixed for com.squareup.okio:okio at versions: 1.17.6, 3.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ xerces:xercesImpl - CVE-2022-23437
Severity: MODERATE
Affected versions of xerces:xercesImpl are vulnerable to XML Injection (aka Blind XPath Injection).

▸▸ Fixed for xerces:xercesImpl at version: 2.12.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2025-53864
Severity: MODERATE
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Uncontrolled Recursion.

▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at versions: 10.0.2, 9.37.4
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-43797
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are
vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2025-25193
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.118.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.fasterxml.woodstox:woodstox-core - CVE-2022-40152
Severity: MODERATE

Affected versions of com.fasterxml.woodstox:woodstox-core are vulnerable to Out-of-bounds Write /
Stack-based Buffer Overflow.

▸▸ Fixed for com.fasterxml.woodstox:woodstox-core at versions: 5.4.0, 6.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❱ commons-configuration:commons-configuration - CVE-2025-46392
Severity: LOW
Affected versions of commons-configuration:commons-configuration are vulnerable to Uncontrolled
Resource Consumption.

▸▸ Fixed for commons-configuration:commons-configuration at version:
1 <?xml version="1.0" encoding="UTF-8"?>

22 Unreachable Supply Chain Findings

pom.xml
❱❱❱ io.netty:netty-handler - CVE-2025-24970
Severity: HIGH
Affected versions of io.netty:netty-handler are vulnerable to Improper Input Validation. A crafted
packet sent to the SslHandler in Netty may not be validated correctly, leading to a potential native
crash. If an attacker exploits this vulnerability by sending specially crafted SSL packets, it risks
destabilizing the application, particularly in high-performance protocol servers relying on Netty

▸▸ Fixed for io.netty:netty-handler at version: 4.1.118.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❱❱❱ org.codehaus.jettison:jettison - CVE-2022-40150
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Uncontrolled Recursion /
Uncontrolled Resource Consumption. Jettison's internal XML/JSON parser may trigger an out-of-memory
condition when processing specially crafted untrusted input, leading to a denial of service attack.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-http2 - CVE-2025-55163
Severity: HIGH
Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to
Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-smtp - CVE-2025-59419
Severity: HIGH
Affected versions of io.netty:netty-codec-smtp are vulnerable to Improper Neutralization of CRLF
Sequences ('CRLF Injection') / Improper Neutralization of Special Elements used in an OS Command
('OS Command Injection'). Allows an attacker who can influence SMTP parameters (MAIL FROM, RCPT TO
or HELO) to inject CRLF sequences and thereby craft arbitrary SMTP commands that the client will
send on behalf of trusted hosts.

▸▸ Fixed for io.netty:netty-codec-smtp at versions: 4.1.128.Final, 4.2.7.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ io.netty:netty - CVE-2019-20444
Severity: CRITICAL
io.netty:netty versions before 4.0.0, org.jboss.netty:netty versions before 4.0.0, and
io.netty:netty-codec-http versions >= 4.0.0 before 4.1.44 are vulnerable to Inconsistent

Interpretation Of Http Requests ('Http Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2023-52428
Severity: HIGH
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Allocation of Resources Without
Limits or Throttling / Uncontrolled Resource Consumption. A denial-of-service vulnerability exists
in Nimbus JOSE+JWT's PBKDF2-based decryption. An attacker can supply an excessively large iteration
count via the JWE p2c header, triggering extreme resource consumption during decryption.

▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at version: 9.37.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ net.minidev:json-smart - CVE-2023-1370
Severity: HIGH
net.minidev:json-smart versions before 2.4.9 are vulnerable to Uncontrolled Recursion leading to
Denial of Service (DoS) due to a StackOverflowError when parsing a deeply nested JSON array or
object.

▸▸ Fixed for net.minidev:json-smart at version: 2.4.9
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty - CVE-2021-37136
Severity: HIGH
Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable
to Uncontrolled Resource Consumption. Netty's Bzip2Decoder fails to impose an upper limit on the
size of decompressed data. This flaw lets attackers supply crafted input that triggers out-of-memory
errors, potentially leading to a denial-of-service condition.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45685

Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The
vulnerability involves a stack overflow, enabling attackers to trigger a Denial of Service (DoS) by
employing specially crafted JSON data.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.code.gson:gson - CVE-2022-25647
Severity: HIGH
Affected versions of com.google.code.gson:gson are vulnerable to Deserialization of Untrusted Data.
Before version 2.8.9, deserializing untrusted data using Java's default serialization (e.g.
`(String) obj.readObject()`) into one of the internal Gson classes `LazilyParsedNumber`,
`LinkedTreeMap` or `LinkedHashTreeMap` can result in a denial of service. These classes are meant to
be serialized and deserialized through Gson's own methods and not through Java's default
serialization. Note that deserializing untrusted data using any method is risky without strict
restrictions on the classes allowed to be deserialized.

▸▸ Fixed for com.google.code.gson:gson at version: 2.8.9
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.airlift:aircompressor - CVE-2024-36114
Severity: HIGH
Affected versions of io.airlift:aircompressor are vulnerable to Out-of-bounds Read / Out-of-bounds
Write. An attacker that provides arbitrary data to be decompressed by airlift can cause the JVM to
crash, and in some cases leak memory content.

▸▸ Fixed for io.airlift:aircompressor at version: 0.27
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.assertj:assertj-core - CVE-2026-24400
Severity: HIGH
Affected versions of org.assertj:assertj-core are vulnerable to Improper Restriction of XML External
Entity Reference. An XXE vulnerability exists in AssertJ's
XmlStringPrettyFormatter.toXmlDocument(String), which initializes DocumentBuilderFactory with

default settings (DTD and external entities enabled). If untrusted XML is passed to
isXmlEqualTo(CharSequence) or xmlPrettyFormat(String), an attacker can read local files, perform
SSRF, or trigger DoS via entity expansion.

▸▸ Fixed for org.assertj:assertj-core at version: 3.27.7

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯❯ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10202
Severity: CRITICAL
Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Deserialization of
Untrusted Data. A flaw in jackson-mapper-asl allows untrusted JSON to be deserialized into arbitrary
Java types via ObjectMapper data-binding APIs, so attacker-controlled input can trigger unsafe
object instantiation during deserialization, enabling critical impact when such input reaches these
code paths.Note:This repository is archived.

▸▸ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯❯ com.jamesmurty.utils:java-xmlbuilder - CVE-2014-125087
Severity: CRITICAL
com.jamesmurty.utils:java-xmlbuilder versions before 1.2 are vulnerable to Improper Restriction Of
Xml External Entity Reference. The parser in `XMLBuilder` and `XMLBuilder2` is vulnerable to XML
External Entity (XXE) injection.

▸▸ Fixed for com.jamesmurty.utils:java-xmlbuilder at version: 1.2

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ io.netty:netty-codec-http - CVE-2025-58056
Severity: LOW
Affected versions of io.netty:netty-codec-http are vulnerable to Inconsistent Interpretation of HTTP
Requests ('HTTP Request/Response Smuggling'). Netty's HTTP chunked-encoding parser treats a lone LF
in a chunk extension as the end of the size line (instead of requiring CRLF per RFC 9112). If a
front-end proxy instead treats that LF as part of the extension, an attacker can craft a "funky

chunks" payload that the proxy sees as one request but Netty splits into two, enabling standard HTTP
request-smuggling attacks—bypassing access controls and corrupting responses to other clients.

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.125.Final, 4.2.5.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty - CVE-2021-37137
Severity: HIGH
Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable
to Uncontrolled Resource Consumption. A lack of input size restrictions in Netty's
SnappyFrameDecoder allows an attacker to send maliciously crafted or oversized compressed frames
(including large skippable chunks) that decompress or buffer to unbounded sizes, resulting in
excessive memory allocations and a denial-of-service.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.fasterxml.jackson.core:jackson-core - GHSA-72hv-8253-57qq
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core and tools.jackson.core:jackson-core are
vulnerable to Allocation of Resources Without Limits or Throttling. Jackson Core's non-blocking
(async) JSON parser bypasses `StreamReadConstraints.maxNumberLength`, allowing an attacker to submit
JSON containing extremely long numeric literals that the async parser will accept and buffer without
length validation. This can trigger excessive memory allocation in the parser's `TextBuffer` and
potentially severe CPU exhaustion during numeric coercion (e.g., `BigInteger`/`BigDecimal` parsing),
resulting in a Denial of Service in applications using the async parser APIs (such as
reactive/WebFlux pipelines).

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at versions: 2.18.6, 2.21.1, 3.1.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2024-47535
Severity: MODERATE

Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.115.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2023-1436
Severity: HIGH
org.codehaus.jettison:jettison versions before 1.5.4 are vulnerable to Uncontrolled Recursion when
constructing a `JSONArray` from a Collection that contains a self-reference in one of its elements.
This leads to a StackOverflowError exception being thrown.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.4
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45693
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The
`org.codehaus.jettison.json.JSONObject` constructor is vulnerable to a `StackOverflowError` when
accepting a HashMap as input. This can lead to Denial of Service (DoS) via crafted string.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ commons-beanutils:commons-beanutils - CVE-2025-48734
Severity: HIGH
Affected versions of commons-beanutils:commons-beanutils and org.apache.commons:commons-beanutils2
are vulnerable to Improper Access Control. Apache Commons BeanUtils is vulnerable to improper access
control where attackers can supply untrusted property paths to methods like getProperty, enabling
access to the enums internal declaredClass property. This bypasses protection mechanisms and could
allow remote attackers to gain control of the ClassLoader, potentially leading to arbitrary code
execution.

▸▸ Fixed for commons-beanutils:commons-beanutils at version: 1.11.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.airlift:aircompressor - CVE-2025-67721
Severity: HIGH
Affected versions of io.airlift:aircompressor and io.airlift:aircompressor-v3 are vulnerable to
Insertion of Sensitive Information Into Sent Data / Out-of-bounds Read. Aircompressor's Java-based
Snappy and LZ4 decompressors do not properly handle malformed compressed data: a crafted input can
cause bytes from a previously used output buffer to be emitted in the new uncompressed output. In
systems that reuse or don't clear the same decompression buffer across calls, this can leak
sensitive data to an attacker.

▸▸ Fixed for io.airlift:aircompressor at version: 2.0.3
1 <?xml version="1.0" encoding="UTF-8"?>

1 Non-blocking Code Finding

src/main/java/org/apache/flink/orc/writer/ThreadLocalClassLoaderConfiguration.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

48 return Class.forName(name, true, getClassLoader());

Scan Summary

✅ CI scan completed successfully.
• Findings: 51 (0 blocking)

• Rules run: 115879
• Targets scanned: 95
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 3
  ◦ Files matching .semgrepignore patterns: 48
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/flink&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/flink&ref=semgrep-uc
  No blocking findings so exiting with code 0

┌──┐
│ 28 Reachable Supply Chain Findings │
└──┘

  src/main/java/org/apache/flink/formats/protobuf/deserialize/PbCodegenArrayDeserializer.java with
  lockfile pom.xml
  ❯❯❱ com.google.protobuf:protobuf-java - CVE-2024-7254
        Severity: HIGH
        Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
        com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
        Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
        unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
        StackOverflow error and lead to a program crash.

        ▸▸┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
        28┆ import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/deserialize/PbCodegenDeserializeFactory.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
29 import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/deserialize/PbCodegenMapDeserializer.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
30 import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/deserialize/PbCodegenRowDeserializer.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,

com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
30 import com.google.protobuf.Descriptors.Descriptor;
⋮ ----------------------------------------
31 import com.google.protobuf.Descriptors.FieldDescriptor;
```

src/main/java/org/apache/flink/formats/protobuf/deserialize/PbCodegenSimpleDeserializer.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
26 import com.google.protobuf.Descriptors;
```

src/main/java/org/apache/flink/formats/protobuf/deserialize/ProtoToRowConverter.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing

unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
 37┆ import com.google.protobuf.ByteString;
  ⋮┆----------------------------------------
 38┆ import com.google.protobuf.Descriptors;
  ⋮┆----------------------------------------
 39┆ import com.google.protobuf.Descriptors.FileDescriptor.Syntax;
```

src/main/java/org/apache/flink/formats/protobuf/serialize/PbCodegenArraySerializer.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
 28┆ import com.google.protobuf.Descriptors;
```

src/main/java/org/apache/flink/formats/protobuf/serialize/PbCodegenMapSerializer.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ ┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
30 ┆ import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/serialize/PbCodegenRowSerializer.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ ┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
31 ┆ import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/serialize/PbCodegenSerializeFactory.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ ┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
29 ┆ import com.google.protobuf.Descriptors;

src/main/java/org/apache/flink/formats/protobuf/serialize/PbCodegenSimpleSerializer.java with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH

Affected versions of com.google.protobuf:protobuf-java,
com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are
vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption.
When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message
can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
28 import com.google.protobuf.Descriptors;
⋮ ----------------------------------------
29 import com.google.protobuf.Descriptors.FieldDescriptor.JavaType;
```

src/main/java/org/apache/flink/formats/protobuf/serialize/PbRowDataSerializationSchema.java
with
lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java,
com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are
vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption.
When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message
can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
30 import com.google.protobuf.Descriptors;
```

src/main/java/org/apache/flink/formats/protobuf/serialize/RowToProtoConverter.java with
lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java,
com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are
vulnerable to

Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
35 import com.google.protobuf.AbstractMessage;
⋮ ----------------------------------------
36 import com.google.protobuf.ByteString;
⋮ ----------------------------------------
37 import com.google.protobuf.Descriptors;
```

src/main/java/org/apache/flink/formats/protobuf/util/PbCodegenUtils.java with lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
29 import com.google.protobuf.Descriptors.FieldDescriptor;
```

src/main/java/org/apache/flink/formats/protobuf/util/PbFormatUtils.java with lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
26 import com.google.protobuf.Descriptors;
⋮ ----------
27 import com.google.protobuf.ProtobufInternalUtils;

src/main/java/org/apache/flink/formats/protobuf/util/PbSchemaValidationUtils.java with lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
29 import com.google.protobuf.Descriptors;
⋮ ----------
30 import com.google.protobuf.Descriptors.FieldDescriptor;
⋮ ----------
31 import com.google.protobuf.Descriptors.FieldDescriptor.JavaType;

src/main/java/org/apache/flink/formats/protobuf/util/PbToRowTypeUtil.java with lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
35 import com.google.protobuf.Descriptors;
⋮ ----------
36 import com.google.protobuf.Descriptors.FieldDescriptor;

⋮┆----------
37┆ import com.google.protobuf.Descriptors.FieldDescriptor.JavaType;

5 Undetermined Supply Chain Findings

pom.xml

❯❯ org.apache.zookeeper:zookeeper - CVE-2024-23944

Severity: MODERATE

Affected versions of org.apache.zookeeper:zookeeper are vulnerable to Exposure of Sensitive Information to an Unauthorized Actor / Missing Authorization.

▸▸┆ Fixed for org.apache.zookeeper:zookeeper at versions: 3.8.4, 3.9.2

1┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.apache.logging.log4j:log4j-core - CVE-2025-68161

Severity: MODERATE

Affected versions of org.apache.logging.log4j:log4j-core are vulnerable to Improper Validation of Certificate with Host Mismatch.

▸▸┆ Fixed for org.apache.logging.log4j:log4j-core at version: 2.25.3

1┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.apache.commons:commons-lang3 - CVE-2025-48924

Severity: MODERATE

Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable to Uncontrolled Recursion.

▸▸┆ Fixed for org.apache.commons:commons-lang3 at version: 3.18.0

1┆ <?xml version="1.0" encoding="UTF-8"?>

❯ com.google.guava:guava - CVE-2020-8908

Severity: LOW

Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File With Insecure Permissions / Exposure of Sensitive Information to an Unauthorized Actor / Improper Handling of Alternate Encoding / Incorrect Permission Assignment for Critical Resource.

▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.google.guava:guava - CVE-2023-2976
Severity: MODERATE
Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File in
Directory with Insecure Permissions / Files or Directories Accessible to External Parties.

▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <?xml version="1.0" encoding="UTF-8"?>

1 Unreachable Supply Chain Finding

pom.xml
❯❯❯ org.assertj:assertj-core - CVE-2026-24400
Severity: HIGH
Affected versions of org.assertj:assertj-core are vulnerable to Improper Restriction of XML External
Entity Reference. An XXE vulnerability exists in AssertJ's
XmlStringPrettyFormatter.toXmlDocument(String), which initializes DocumentBuilderFactory with
default settings (DTD and external entities enabled). If untrusted XML is passed to
isXmlEqualTo(CharSequence) or xmlPrettyFormat(String), an attacker can read local files, perform
SSRF, or trigger DoS via entity expansion.

▸▸ Fixed for org.assertj:assertj-core at version: 3.27.7
1 <?xml version="1.0" encoding="UTF-8"?>

2 Non-blocking Code Findings

src/main/java/org/apache/flink/formats/protobuf/deserialize/ProtoToRowConverter.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow

paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
66 Class.forName(
67         formatConfig.getMessageClassName(),
68         true,
69         Thread.currentThread().getContextClassLoader());
```

src/main/java/org/apache/flink/formats/protobuf/util/PbFormatUtils.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
121 Class.forName(className, true, Thread.currentThread().getContextClassLoader());
```

┌──────────────┐
│ Scan Summary │
└──────────────┘

✅ CI scan completed successfully.
• Findings: 36 (0 blocking)
• Rules run: 116510
• Targets scanned: 50
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 2
  ◦ Files matching .semgrepignore patterns: 66
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/flink&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/flink&ref=semgrep-uc
No blocking findings so exiting with code 0

⏫ A new version of Semgrep is available. See https://semgrep.dev/docs/upgrading

```
┌──────────────────────────────────────────────────────────┐
│ 13 Reachable Supply Chain Findings │
└──────────────────────────────────────────────────────────┘
```

pom.xml
❯❯❱ org.apache.thrift:libthrift - CVE-2019-0205
Severity: HIGH
org.apache.thrift:libthrift versions before and including 0.12.0 are vulnerable to Loop With
Unreachable Exit Condition ('Infinite Loop'). A server or client may run into an endless loop when
fed with specific input data. This bug only affects certain language bindings; any languages not
listed here were either patched in an earlier release or were never affected: `as, cpp, c_gsrc, d,
dart, go, javame, js, lua, nodejs, ocaml, py, rb, swift`.

▸▸┆ Fixed for org.apache.thrift:libthrift at version: 0.13.0
1┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❱ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10172
Severity: HIGH
Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Improper Restriction
Of Xml External Entity Reference. The primary threat from this flaw is data integrity. The repo was
archived in Nov 2022 and is no longer supported. The recommendation is to remove Codehaus and update
to FasterXML.

▸▸┆ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:
1┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❱ io.netty:netty-codec-http2 - CVE-2025-55163

Severity: HIGH
Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to
Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service. This is a protocol level attack.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ net.minidev:json-smart - CVE-2021-27568
Severity: MODERATE
Affected versions of net.minidev:json-smart 2.3.x before 2.3.1, net.minidev:json-smart 2.4.x before
2.4.1, net.minidev:json-smart-mini 1.3.x before 1.3.2, and net.minidev:json-smart 1.3.x before 1.3.2
are vulnerable to Improper Check For Unusual Or Exceptional Conditions. The vulnerability arises
from an uncaught exception (e.g., NumberFormatException) thrown from a function, potentially causing
program crashes or sensitive information exposure, as the parser fails to generate a ParseException
when expecting float number input that is not valid, resulting in unhandled exceptions and potential
Denial-of-Service (DoS) scenarios due to unexpected input.

▸▸ Fixed for net.minidev:json-smart at versions: 1.3.2, 2.3.1, 2.4.1

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ com.sun.jersey:jersey-core - CVE-2014-3643
Severity: HIGH
Affected versions of com.sun.jersey:jersey-core are vulnerable to Improper Restriction of XML

External Entity Reference. Jersey's built-in SAX XML parser does not disable parameter entity
processing, leaving any XML-consuming endpoint vulnerable to XXE. An attacker can submit crafted XML
with external parameter entities to read internal files or trigger server-side requests.

```
▸▸ Fixed for com.sun.jersey:jersey-core at version: 1.13
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ org.apache.thrift:libthrift - CVE-2018-1320
Severity: HIGH
Affected versions of org.apache.thrift:libthrift are vulnerable to Improper Certificate Validation /
Improper Input Validation. An assert in the TSaslTransport class that verifies SASL handshake
completion can be disabled when Java assertions are turned off, causing the isComplete check to be
skipped. This allows a malicious or man-in-the-middle server to bypass SASL authentication and send
unauthorized RPC calls.

```
▸▸ Fixed for org.apache.thrift:libthrift at versions: 0.12.0, 0.9.3-1
 1 <?xml version="1.0" encoding="UTF-8"?>
```

src/main/java/org/apache/flink/formats/parquet/avro/AvroParquetReaders.java with lockfile pom.xml
❯❯❯ org.apache.parquet:parquet-avro - CVE-2025-46762
Severity: HIGH
Affected versions of org.apache.parquet:parquet-avro are vulnerable to External Control of File Name
or Path. Parquet Javas Avro module is vulnerable to arbitrary code execution when using its
`specific` or `reflect` deserialization models. A malicious actor could leverage this flaw during
schema parsing to trigger execution of an injected, malicious class, potentially compromising system
security.

```
▸▸ Fixed for org.apache.parquet:parquet-avro at version: 1.15.2
54 new AvroTypeInfo<>(typeClass), () -> SpecificData.get());
 ⋮ ----------------------------------------
87 TypeExtractor.createTypeInfo(typeClass), () -> ReflectData.get());
```

src/main/java/org/apache/flink/formats/parquet/avro/AvroParquetWriters.java with lockfile

pom.xml
❯❯❯ org.apache.parquet:parquet-avro - CVE-2025-46762
Severity: HIGH
Affected versions of org.apache.parquet:parquet-avro are vulnerable to External Control of File Name
or Path. Parquet Javas Avro module is vulnerable to arbitrary code execution when using its
`specific` or `reflect` deserialization models. A malicious actor could leverage this flaw during
schema parsing to trigger execution of an injected, malicious class, potentially compromising system
security.

▸▸ Fixed for org.apache.parquet:parquet-avro at version: 1.15.2
51 final String schemaString = SpecificData.get().getSchema(type).toString();
⋮ ----------
53 (out) -> createAvroParquetWriter(schemaString, SpecificData.get(), out);
⋮ ----------
85 final String schemaString = ReflectData.get().getSchema(type).toString();
⋮ ----------
87 (out) -> createAvroParquetWriter(schemaString, ReflectData.get(), out);

src/main/java/org/apache/flink/formats/parquet/protobuf/ParquetProtoWriters.java with lockfile
pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
24 import com.google.protobuf.Message;

21 Undetermined Supply Chain Findings

pom.xml

❯❯ org.apache.zookeeper:zookeeper - CVE-2024-23944

Severity: MODERATE

Affected versions of org.apache.zookeeper:zookeeper are vulnerable to Exposure of Sensitive

Information to an Unauthorized Actor / Missing Authorization.

▸▸ Fixed for org.apache.zookeeper:zookeeper at versions: 3.8.4, 3.9.2

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ commons-net:commons-net - CVE-2021-37533

Severity: MODERATE

Affected versions of commons-net:commons-net are vulnerable to Improper Input Validation.

▸▸ Fixed for commons-net:commons-net at version: 3.9.0

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec - CVE-2025-58057

Severity: MODERATE

Affected versions of io.netty:netty-codec and io.netty:netty-codec-compression are vulnerable to

Improper Handling of Highly Compressed Data (Data Amplification).

▸▸ Fixed for io.netty:netty-codec at version: 4.1.125.Final

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty - CVE-2021-21409

Severity: MODERATE

Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are

vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ org.apache.logging.log4j:log4j-core - CVE-2025-68161

Severity: MODERATE

Affected versions of org.apache.logging.log4j:log4j-core are vulnerable to Improper Validation of

Certificate with Host Mismatch.

▸▸ Fixed for org.apache.logging.log4j:log4j-core at version: 2.25.3

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ commons-lang:commons-lang - CVE-2025-48924
Severity: MODERATE
Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable
to Uncontrolled Recursion.

▸▸ Fixed for commons-lang:commons-lang at version:
1 <?xml version="1.0" encoding="UTF-8"?>
⋮ ----------
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2019-20445
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-handler, and org.jboss.netty:netty are
vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec-http - CVE-2025-67735
Severity: MODERATE
Affected versions of io.netty:netty-codec-http are vulnerable to Improper Neutralization of CRLF
Sequences ('CRLF Injection').

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.129.Final, 4.2.8.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯ org.apache.hadoop:hadoop-common - CVE-2024-23454
Severity: LOW
Affected versions of org.apache.hadoop:hadoop-common are vulnerable to Creation of Temporary File
With Insecure Permissions / Improper Privilege Management.

▸▸ Fixed for org.apache.hadoop:hadoop-common at version: 3.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21290
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are
vulnerable to Creation of Temporary File With Insecure Permissions / Creation of Temporary File in

Directory with Insecure Permissions / Exposure of Resource to Wrong Sphere.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21295
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.codehaus.jettison:jettison - CVE-2022-40149
Severity: MODERATE
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-of-bounds Write / Stack-based Buffer Overflow.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec-http - CVE-2024-29025
Severity: MODERATE
Affected versions of io.netty:netty-codec-http are vulnerable to Allocation of Resources Without Limits or Throttling.

▸▸ Fixed for io.netty:netty-codec-http at version: 4.1.108.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.squareup.okio:okio - CVE-2023-3635
Severity: MODERATE
Affected versions of com.squareup.okio:okio and com.squareup.okio:okio-jvm are vulnerable to Incorrect Conversion between Numeric Types / Signed to Unsigned Conversion Error.

▸▸ Fixed for com.squareup.okio:okio at versions: 1.17.6, 3.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ xerces:xercesImpl - CVE-2022-23437
Severity: MODERATE

Affected versions of xerces:xercesImpl are vulnerable to XML Injection (aka Blind XPath Injection).

```
▸▸ Fixed for xerces:xercesImpl at version: 2.12.2
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2025-53864
Severity: MODERATE
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Uncontrolled Recursion.

```
▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at versions: 10.0.2, 9.37.4
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty - CVE-2021-43797
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

```
▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-common - CVE-2025-25193
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

```
▸▸ Fixed for io.netty:netty-common at version: 4.1.118.Final
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ com.fasterxml.woodstox:woodstox-core - CVE-2022-40152
Severity: MODERATE
Affected versions of com.fasterxml.woodstox:woodstox-core are vulnerable to Out-of-bounds Write /
Stack-based Buffer Overflow.

```
▸▸ Fixed for com.fasterxml.woodstox:woodstox-core at versions: 5.4.0, 6.4.0
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ commons-configuration:commons-configuration - CVE-2025-46392
Severity: LOW
Affected versions of commons-configuration:commons-configuration are vulnerable to Uncontrolled

Resource Consumption.

▸▸ Fixed for commons-configuration:commons-configuration at version:
1 <?xml version="1.0" encoding="UTF-8"?>

24 Unreachable Supply Chain Findings

pom.xml

❯❯❯ io.netty:netty-handler - CVE-2025-24970

Severity: HIGH

Affected versions of io.netty:netty-handler are vulnerable to Improper Input Validation. A crafted packet sent to the SslHandler in Netty may not be validated correctly, leading to a potential native crash. If an attacker exploits this vulnerability by sending specially crafted SSL packets, it risks destabilizing the application, particularly in high-performance protocol servers relying on Netty

▸▸ Fixed for io.netty:netty-handler at version: 4.1.118.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-40150

Severity: HIGH

Affected versions of org.codehaus.jettison:jettison are vulnerable to Uncontrolled Recursion / Uncontrolled Resource Consumption. Jettison's internal XML/JSON parser may trigger an out-of-memory condition when processing specially crafted untrusted input, leading to a denial of service attack.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-http2 - CVE-2025-55163

Severity: HIGH

Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to

correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-smtp - CVE-2025-59419
Severity: HIGH
Affected versions of io.netty:netty-codec-smtp are vulnerable to Improper Neutralization of CRLF
Sequences ('CRLF Injection') / Improper Neutralization of Special Elements used in an OS Command
('OS Command Injection'). Allows an attacker who can influence SMTP parameters (MAIL FROM, RCPT TO
or HELO) to inject CRLF sequences and thereby craft arbitrary SMTP commands that the client will
send on behalf of trusted hosts.

▸▸ Fixed for io.netty:netty-codec-smtp at versions: 4.1.128.Final, 4.2.7.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ io.netty:netty - CVE-2019-20444
Severity: CRITICAL
io.netty:netty versions before 4.0.0, org.jboss.netty:netty versions before 4.0.0, and
io.netty:netty-codec-http versions >= 4.0.0 before 4.1.44 are vulnerable to Inconsistent
Interpretation Of Http Requests ('Http Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2023-52428
Severity: HIGH
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Allocation of Resources Without

Limits or Throttling / Uncontrolled Resource Consumption. A denial-of-service vulnerability exists
in Nimbus JOSE+JWT's PBKDF2-based decryption. An attacker can supply an excessively large iteration
count via the JWE p2c header, triggering extreme resource consumption during decryption.

▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at version: 9.37.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ net.minidev:json-smart - CVE-2023-1370
Severity: HIGH
net.minidev:json-smart versions before 2.4.9 are vulnerable to Uncontrolled Recursion leading to
Denial of Service (DoS) due to a StackOverflowError when parsing a deeply nested JSON array or
object.

▸▸ Fixed for net.minidev:json-smart at version: 2.4.9
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty - CVE-2021-37136
Severity: HIGH
Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable
to Uncontrolled Resource Consumption. Netty's Bzip2Decoder fails to impose an upper limit on the
size of decompressed data. This flaw lets attackers supply crafted input that triggers out-of-memory
errors, potentially leading to a denial-of-service condition.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45685
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The
vulnerability involves a stack overflow, enabling attackers to trigger a Denial of Service (DoS) by
employing specially crafted JSON data.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.code.gson:gson - CVE-2022-25647

Severity: HIGH

Affected versions of com.google.code.gson:gson are vulnerable to Deserialization of Untrusted Data.

Before version 2.8.9, deserializing untrusted data using Java's default serialization (e.g. `(String) obj.readObject()`) into one of the internal Gson classes `LazilyParsedNumber`, `LinkedTreeMap` or `LinkedHashTreeMap` can result in a denial of service. These classes are meant to be serialized and deserialized through Gson's own methods and not through Java's default serialization. Note that deserializing untrusted data using any method is risky without strict restrictions on the classes allowed to be deserialized.

▸▸ Fixed for com.google.code.gson:gson at version: 2.8.9

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯❯ org.apache.parquet:parquet-avro - CVE-2025-30065

Severity: CRITICAL

Affected versions of org.apache.parquet:parquet-avro are vulnerable to Deserialization of Untrusted Data. The `parquet-avro` module in this package fails to properly validate input schemas, allowing an attacker to supply a malicious schema that could trigger arbitrary code execution during schema parsing.

▸▸ Fixed for org.apache.parquet:parquet-avro at version: 1.15.1

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ io.airlift:aircompressor - CVE-2024-36114

Severity: HIGH

Affected versions of io.airlift:aircompressor are vulnerable to Out-of-bounds Read / Out-of-bounds Write. An attacker that provides arbitrary data to be decompressed by airlift can cause the JVM to crash, and in some cases leak memory content.

▸▸ Fixed for io.airlift:aircompressor at version: 0.27

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ org.assertj:assertj-core - CVE-2026-24400

Severity: HIGH

Affected versions of org.assertj:assertj-core are vulnerable to Improper Restriction of XML External
Entity Reference. An XXE vulnerability exists in AssertJ's
XmlStringPrettyFormatter.toXmlDocument(String), which initializes DocumentBuilderFactory with
default settings (DTD and external entities enabled). If untrusted XML is passed to
isXmlEqualTo(CharSequence) or xmlPrettyFormat(String), an attacker can read local files, perform
SSRF, or trigger DoS via entity expansion.

▸▸ Fixed for org.assertj:assertj-core at version: 3.27.7

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯❯ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10202
Severity: CRITICAL
Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Deserialization of
Untrusted Data. A flaw in jackson-mapper-asl allows untrusted JSON to be deserialized into arbitrary
Java types via ObjectMapper data-binding APIs, so attacker-controlled input can trigger unsafe
object instantiation during deserialization, enabling critical impact when such input reaches these
code paths.Note:This repository is archived.

▸▸ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯❯ com.jamesmurty.utils:java-xmlbuilder - CVE-2014-125087
Severity: CRITICAL
com.jamesmurty.utils:java-xmlbuilder versions before 1.2 are vulnerable to Improper Restriction Of
Xml External Entity Reference. The parser in `XMLBuilder` and `XMLBuilder2` is vulnerable to XML
External Entity (XXE) injection.

▸▸ Fixed for com.jamesmurty.utils:java-xmlbuilder at version: 1.2

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ io.netty:netty-codec-http - CVE-2025-58056
Severity: LOW
Affected versions of io.netty:netty-codec-http are vulnerable to Inconsistent Interpretation of HTTP

Requests ('HTTP Request/Response Smuggling'). Netty's HTTP chunked-encoding parser treats a lone LF
in a chunk extension as the end of the size line (instead of requiring CRLF per RFC 9112). If a
front-end proxy instead treats that LF as part of the extension, an attacker can craft a "funky
chunks" payload that the proxy sees as one request but Netty splits into two, enabling standard HTTP
request-smuggling attacks—bypassing access controls and corrupting responses to other clients.

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.125.Final, 4.2.5.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.apache.thrift:libthrift - CVE-2018-1320
Severity: HIGH
Affected versions of org.apache.thrift:libthrift are vulnerable to Improper Certificate Validation /
Improper Input Validation. An assert in the TSaslTransport class that verifies SASL handshake
completion can be disabled when Java assertions are turned off, causing the isComplete check to be
skipped. This allows a malicious or man-in-the-middle server to bypass SASL authentication and send
unauthorized RPC calls.

▸▸ Fixed for org.apache.thrift:libthrift at versions: 0.12.0, 0.9.3-1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty - CVE-2021-37137
Severity: HIGH
Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable
to Uncontrolled Resource Consumption. A lack of input size restrictions in Netty's
SnappyFrameDecoder allows an attacker to send maliciously crafted or oversized compressed frames
(including large skippable chunks) that decompress or buffer to unbounded sizes, resulting in
excessive memory allocations and a denial-of-service.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.fasterxml.jackson.core:jackson-core - GHSA-72hv-8253-57qq

Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core and tools.jackson.core:jackson-core are
vulnerable to Allocation of Resources Without Limits or Throttling. Jackson Core's non-blocking
(async) JSON parser bypasses `StreamReadConstraints.maxNumberLength`, allowing an attacker to submit
JSON containing extremely long numeric literals that the async parser will accept and buffer without
length validation. This can trigger excessive memory allocation in the parser's `TextBuffer` and
potentially severe CPU exhaustion during numeric coercion (e.g., `BigInteger`/`BigDecimal` parsing),
resulting in a Denial of Service in applications using the async parser APIs (such as
reactive/WebFlux pipelines).

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at versions: 2.18.6, 2.21.1, 3.1.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2024-47535
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.115.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2023-1436
Severity: HIGH
org.codehaus.jettison:jettison versions before 1.5.4 are vulnerable to Uncontrolled Recursion when
constructing a `JSONArray` from a Collection that contains a self-reference in one of its elements.
This leads to a StackOverflowError exception being thrown.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.4
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45693
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The
`org.codehaus.jettison.json.JSONObject` constructor is vulnerable to a `StackOverflowError` when

accepting a HashMap as input. This can lead to Denial of Service (DoS) via crafted string.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ commons-beanutils:commons-beanutils - CVE-2025-48734
Severity: HIGH
Affected versions of commons-beanutils:commons-beanutils and org.apache.commons:commons-beanutils2
are vulnerable to Improper Access Control. Apache Commons BeanUtils is vulnerable to improper access
control where attackers can supply untrusted property paths to methods like getProperty, enabling
access to the enums internal declaredClass property. This bypasses protection mechanisms and could
allow remote attackers to gain control of the ClassLoader, potentially leading to arbitrary code
execution.

▸▸ Fixed for commons-beanutils:commons-beanutils at version: 1.11.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.airlift:aircompressor - CVE-2025-67721
Severity: HIGH
Affected versions of io.airlift:aircompressor and io.airlift:aircompressor-v3 are vulnerable to
Insertion of Sensitive Information Into Sent Data / Out-of-bounds Read. Aircompressor's Java-based
Snappy and LZ4 decompressors do not properly handle malformed compressed data: a crafted input can
cause bytes from a previously used output buffer to be emitted in the new uncompressed output. In
systems that reuse or don't clear the same decompression buffer across calls, this can leak
sensitive data to an attacker.

▸▸ Fixed for io.airlift:aircompressor at version: 2.0.3
1 <?xml version="1.0" encoding="UTF-8"?>

Scan Summary

✅ CI scan completed successfully.
• Findings: 58 (0 blocking)
• Rules run: 116510
• Targets scanned: 112
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 4
  ◦ Files matching .semgrepignore patterns: 60
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.

```
┌──────────────────────────────────────────┐
│ 1 Reachable Supply Chain Finding │
└──────────────────────────────────────────┘
```

src/main/java/org/apache/flink/metrics/datadog/DatadogHttpClient.java with lockfile pom.xml
❯❯❱ com.squareup.okhttp3:okhttp - CVE-2021-0341
Severity: HIGH
Affected versions of com.squareup.okhttp3:okhttp are vulnerable to Improper Certificate Validation.
Improper hostname verification in OkHttp's OkHostnameVerifier.verifyHostName can allow an attacker
to present a certificate for the wrong domain, bypassing TLS checks and causing OkHttp to accept a
malicious cert for an unintended host. This can lead to remote information disclosure without any
user interaction.

▶▶┆ Fixed for com.squareup.okhttp3:okhttp at version: 4.9.2
101┆ try (Response response = client.newCall(r).execute()) {

```
┌──────────────────────────────────────────┐
│ 3 Undetermined Supply Chain Findings │
└──────────────────────────────────────────┘
```

pom.xml
❯❱ org.apache.logging.log4j:log4j-core - CVE-2025-68161
Severity: MODERATE

Affected versions of org.apache.logging.log4j:log4j-core are vulnerable to Improper Validation of
Certificate with Host Mismatch.

▸▸ Fixed for org.apache.logging.log4j:log4j-core at version: 2.25.3
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.apache.commons:commons-lang3 - CVE-2025-48924
Severity: MODERATE
Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable
to Uncontrolled Recursion.

▸▸ Fixed for org.apache.commons:commons-lang3 at version: 3.18.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.squareup.okio:okio - CVE-2023-3635
Severity: MODERATE
Affected versions of com.squareup.okio:okio and com.squareup.okio:okio-jvm are vulnerable to
Incorrect Conversion between Numeric Types / Signed to Unsigned Conversion Error.

▸▸ Fixed for com.squareup.okio:okio at versions: 1.17.6, 3.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

1 Unreachable Supply Chain Finding

pom.xml
❯❯❯ org.assertj:assertj-core - CVE-2026-24400
Severity: HIGH
Affected versions of org.assertj:assertj-core are vulnerable to Improper Restriction of XML External
Entity Reference. An XXE vulnerability exists in AssertJ's
XmlStringPrettyFormatter.toXmlDocument(String), which initializes DocumentBuilderFactory with
default settings (DTD and external entities enabled). If untrusted XML is passed to
isXmlEqualTo(CharSequence) or xmlPrettyFormat(String), an attacker can read local files, perform
SSRF, or trigger DoS via entity expansion.

▸▸ Fixed for org.assertj:assertj-core at version: 3.27.7

```
1 ┆ <?xml version="1.0" encoding="UTF-8"?>
```

```
┌──────────────────────────────────────┐
│ 1 Non-blocking Code Finding │
└──────────────────────────────────────┘

  test_generation_data/agent_flink-metrics-datadog.log
❯❯❱ generic.secrets.security.detected-mailgun-api-key.detected-mailgun-api-key
      Mailgun API Key detected
      Details: https://sg.run/jRL2

      10536 ┆ String apiKey = "test-api-key-1234567890abcdef1234567890abcdef";
```

```
┌──────────────────┐
│ Scan Summary │
└──────────────────┘
```

✅ CI scan completed successfully.
• Findings: 6 (0 blocking)
• Rules run: 116516
• Targets scanned: 31
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 1
  ◦ Files matching .semgrepignore patterns: 18
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/flink&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/flink&ref=semgrep-uc
  No blocking findings so exiting with code 0

```
┌──────────────────────────────────────────┐
│ 11 Reachable Supply Chain Findings │
└──────────────────────────────────────────┘
```

pom.xml

❯❯❯ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10172

Severity: HIGH

Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Improper Restriction Of Xml External Entity Reference. The primary threat from this flaw is data integrity. The repo was archived in Nov 2022 and is no longer supported. The recommendation is to remove Codehaus and update to FasterXML.

```
▸▸ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ io.netty:netty-codec-http2 - CVE-2025-55163

Severity: HIGH

Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to correctly track active streams when sending RST_STREAM in response to certain malformed control frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment, HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs; each reset decrements Netty's concurrent-stream counter even though the request is still processed. By repeating this on a single connection, the attacker can open an unbounded number of streams, exhausting CPU and memory and causing a denial of service. This is a protocol level attack.

```
▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ net.minidev:json-smart - CVE-2021-27568

Severity: MODERATE

Affected versions of net.minidev:json-smart 2.3.x before 2.3.1, net.minidev:json-smart 2.4.x before 2.4.1, net.minidev:json-smart-mini 1.3.x before 1.3.2, and net.minidev:json-smart 1.3.x before 1.3.2 are vulnerable to Improper Check For Unusual Or Exceptional Conditions. The vulnerability arises

from an uncaught exception (e.g., NumberFormatException) thrown from a function, potentially causing
program crashes or sensitive information exposure, as the parser fails to generate a ParseException
when expecting float number input that is not valid, resulting in unhandled exceptions and potential
Denial-of-Service (DoS) scenarios due to unexpected input.

▸▸ Fixed for net.minidev:json-smart at versions: 1.3.2, 2.3.1, 2.4.1
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.sun.jersey:jersey-core - CVE-2014-3643
Severity: HIGH
Affected versions of com.sun.jersey:jersey-core are vulnerable to Improper Restriction of XML
External Entity Reference. Jersey's built-in SAX XML parser does not disable parameter entity
processing, leaving any XML-consuming endpoint vulnerable to XXE. An attacker can submit crafted XML
with external parameter entities to read internal files or trigger server-side requests.

▸▸ Fixed for com.sun.jersey:jersey-core at version: 1.13
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.protobuf:protobuf-java - CVE-2021-22569
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java and com.google.protobuf:protobuf-kotlin are
vulnerable to Incorrect Behavior Order. Parsing of unknown fields in the Java Protobuf runtime can
be abused by a crafted binary payload (~800 KB) to trigger excessive short-lived object allocations,
causing repeated GC pauses and prolonged parsing times, resulting in a Denial of Service.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.1, 3.18.2, 3.19.2
1 <?xml version="1.0" encoding="UTF-8"?>

src/main/java/org/apache/flink/runtime/io/compression/Lz4BlockDecompressor.java with lockfile
pom.xml
❯❯❯ org.lz4:lz4-java - CVE-2025-12183
Severity: HIGH
Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and

org.lz4:lz4-pure-java are vulnerable to Out-of-bounds Read. A vulnerability in LZ4 Java's decompression logic allows untrusted compressed input to trigger out-of-bounds memory operations,
leading to JVM crashes (denial of service) or disclosure of adjacent memory.

▸▸ Fixed for org.lz4:lz4-java at version: 1.8.1
43 this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

Taint comes from:

43 this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

This is how taint reaches the sink:

43 this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

⋮ ----------

❯❯❯ org.lz4:lz4-java - CVE-2025-66566
Severity: HIGH
Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and org.lz4:lz4-pure-java are vulnerable to Insertion of Sensitive Information Into Sent Data. In lz4-java's pure-Java decompressor implementations (safeInstance(), unsafeInstance(), fastestJavaInstance(), fastDecompressor()), insufficient clearing of the output buffer allows a
crafted compressed input to copy from uninitialized regions of a reused buffer—potentially leaking
residual or sensitive data. The JNI-based safeDecompressor is not affected. Users who reuse buffers
without zeroing them before decompression are at risk.

▸▸ Fixed for org.lz4:lz4-java at version:
43 this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

Taint comes from:

43 this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

This is how taint reaches the sink:

```
43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

⋮┆----------

❯❯❯ org.lz4:lz4-java - CVE-2025-12183

Severity: HIGH

Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and org.lz4:lz4-pure-java are vulnerable to Out-of-bounds Read. A vulnerability in LZ4 Java's decompression logic allows untrusted compressed input to trigger out-of-bounds memory operations, leading to JVM crashes (denial of service) or disclosure of adjacent memory.

```
▸▸ ┆ Fixed for org.lz4:lz4-java at version: 1.8.1
68 ┆ decompressor.decompress(
69 ┆         src, prevSrcOff + HEADER_LENGTH, dst, prevDstOff, originalLen);
```

Taint comes from:

```
43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

Taint flows through these intermediate variables:

```
43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

This is how taint reaches the sink:

```
68 ┆ decompressor.decompress(

69 ┆         src, prevSrcOff + HEADER_LENGTH, dst, prevDstOff, originalLen);
```

⋮┆----------

❯❯❯ org.lz4:lz4-java - CVE-2025-66566

Severity: HIGH

Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and org.lz4:lz4-pure-java are vulnerable to Insertion of Sensitive Information Into Sent Data. In

lz4-java's pure-Java decompressor implementations (safeInstance(), unsafeInstance(), fastestJavaInstance(), fastDecompressor()), insufficient clearing of the output buffer allows a crafted compressed input to copy from uninitialized regions of a reused buffer—potentially leaking residual or sensitive data. The JNI-based safeDecompressor is not affected. Users who reuse buffers without zeroing them before decompression are at risk.

▸▸ Fixed for org.lz4:lz4-java at version:

```
68  decompressor.decompress(
69          src, prevSrcOff + HEADER_LENGTH, dst, prevDstOff, originalLen);
```

Taint comes from:

```
43  this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

Taint flows through these intermediate variables:

```
43  this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

43  this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

This is how taint reaches the sink:

```
68  decompressor.decompress(

69          src, prevSrcOff + HEADER_LENGTH, dst, prevDstOff, originalLen);
```

⋮ ----------

❯❯❯ org.lz4:lz4-java - CVE-2025-12183

Severity: HIGH

Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and org.lz4:lz4-pure-java are vulnerable to Out-of-bounds Read. A vulnerability in LZ4 Java's decompression logic allows untrusted compressed input to trigger out-of-bounds memory operations, leading to JVM crashes (denial of service) or disclosure of adjacent memory.

▸▸ Fixed for org.lz4:lz4-java at version: 1.8.1

101 ┆ decompressor.decompress(src, srcOff + HEADER_LENGTH, dst, dstOff, originalLen);

Taint comes from:

43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

Taint flows through these intermediate variables:

43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

This is how taint reaches the sink:

101 ┆ decompressor.decompress(src, srcOff + HEADER_LENGTH, dst, dstOff, originalLen);

⋮ ┆ ----------

❯❯❯ org.lz4:lz4-java - CVE-2025-66566

Severity: HIGH

Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and org.lz4:lz4-pure-java are vulnerable to Insertion of Sensitive Information Into Sent Data. In lz4-java's pure-Java decompressor implementations (safeInstance(), unsafeInstance(), fastestJavaInstance(), fastDecompressor()), insufficient clearing of the output buffer allows a crafted compressed input to copy from uninitialized regions of a reused buffer—potentially leaking residual or sensitive data. The JNI-based safeDecompressor is not affected. Users who reuse buffers without zeroing them before decompression are at risk.

▸▸ ┆ Fixed for org.lz4:lz4-java at version:

101 ┆ decompressor.decompress(src, srcOff + HEADER_LENGTH, dst, dstOff, originalLen);

Taint comes from:

```
43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

Taint flows through these intermediate variables:

```
43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();

43 ┆ this.decompressor = LZ4Factory.fastestInstance().fastDecompressor();
```

This is how taint reaches the sink:

```
101 ┆ decompressor.decompress(src, srcOff + HEADER_LENGTH, dst, dstOff,
originalLen);
```

25 Undetermined Supply Chain Findings

pom.xml

❯❯ org.apache.zookeeper:zookeeper - CVE-2024-23944

Severity: MODERATE

Affected versions of org.apache.zookeeper:zookeeper are vulnerable to Exposure of Sensitive Information to an Unauthorized Actor / Missing Authorization.

```
▸▸ ┆ Fixed for org.apache.zookeeper:zookeeper at versions: 3.8.4, 3.9.2
 1 ┆ <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ commons-net:commons-net - CVE-2021-37533

Severity: MODERATE

Affected versions of commons-net:commons-net are vulnerable to Improper Input Validation.

```
▸▸ ┆ Fixed for commons-net:commons-net at version: 3.9.0
 1 ┆ <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ io.netty:netty-codec - CVE-2025-58057

Severity: MODERATE

Affected versions of io.netty:netty-codec and io.netty:netty-codec-compression are vulnerable to Improper Handling of Highly Compressed Data (Data Amplification).

▸▸ Fixed for io.netty:netty-codec at version: 4.1.125.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21409
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.apache.logging.log4j:log4j-core - CVE-2025-68161
Severity: MODERATE
Affected versions of org.apache.logging.log4j:log4j-core are vulnerable to Improper Validation of
Certificate with Host Mismatch.

▸▸ Fixed for org.apache.logging.log4j:log4j-core at version: 2.25.3
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ commons-lang:commons-lang - CVE-2025-48924
Severity: MODERATE
Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable
to Uncontrolled Recursion.

▸▸ Fixed for commons-lang:commons-lang at version:
1 <?xml version="1.0" encoding="UTF-8"?>
⋮ ----------
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2019-20445
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-handler, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec-http - CVE-2025-67735
Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Improper Neutralization of CRLF
Sequences ('CRLF Injection').

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.129.Final, 4.2.8.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯ com.google.guava:guava - CVE-2020-8908
Severity: LOW
Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File With
Insecure Permissions / Exposure of Sensitive Information to an Unauthorized Actor / Improper
Handling of Alternate Encoding / Incorrect Permission Assignment for Critical Resource.

▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <?xml version="1.0" encoding="UTF-8"?>

❯ org.apache.hadoop:hadoop-common - CVE-2024-23454
Severity: LOW
Affected versions of org.apache.hadoop:hadoop-common are vulnerable to Creation of Temporary File
With Insecure Permissions / Improper Privilege Management.

▸▸ Fixed for org.apache.hadoop:hadoop-common at version: 3.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21290
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are
vulnerable to Creation of Temporary File With Insecure Permissions / Creation of Temporary File in
Directory with Insecure Permissions / Exposure of Resource to Wrong Sphere.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.google.protobuf:protobuf-java - CVE-2022-3171
Severity: MODERATE
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.3, 3.19.6, 3.20.3, 3.21.7

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-21295

Severity: MODERATE

Affected versions of io.netty:netty, io.netty:netty-codec-http2, and org.jboss.netty:netty are vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ org.codehaus.jettison:jettison - CVE-2022-40149

Severity: MODERATE

Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-of-bounds Write / Stack-based Buffer Overflow.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.1

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-codec-http - CVE-2024-29025

Severity: MODERATE

Affected versions of io.netty:netty-codec-http are vulnerable to Allocation of Resources Without Limits or Throttling.

▸▸ Fixed for io.netty:netty-codec-http at version: 4.1.108.Final

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.squareup.okio:okio - CVE-2023-3635

Severity: MODERATE

Affected versions of com.squareup.okio:okio and com.squareup.okio:okio-jvm are vulnerable to Incorrect Conversion between Numeric Types / Signed to Unsigned Conversion Error.

▸▸ Fixed for com.squareup.okio:okio at versions: 1.17.6, 3.4.0

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ xerces:xercesImpl - CVE-2022-23437

Severity: MODERATE

Affected versions of xerces:xercesImpl are vulnerable to XML Injection (aka Blind XPath Injection).

▸▸ Fixed for xerces:xercesImpl at version: 2.12.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.google.guava:guava - CVE-2018-10237
Severity: MODERATE
Affected versions of com.google.guava:guava, com.google.guava:guava-jdk5, com.googlecode.guava-
osgi:guava-osgi, de.mhus.ports:vaadin-shared-deps, org.hudsonci.lib.guava:guava, and
org.sonatype.sisu:sisu-guava are vulnerable to Allocation of Resources Without Limits or Throttling
/ Deserialization of Untrusted Data.

▸▸ Fixed for com.google.guava:guava at version: 24.1.1-android
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.google.guava:guava - CVE-2023-2976
Severity: MODERATE
Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File in
Directory with Insecure Permissions / Files or Directories Accessible to External Parties.

▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2025-53864
Severity: MODERATE
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Uncontrolled Recursion.

▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at versions: 10.0.2, 9.37.4
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty - CVE-2021-43797
Severity: MODERATE
Affected versions of io.netty:netty, io.netty:netty-codec-http, and org.jboss.netty:netty are
vulnerable to Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2025-25193
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.118.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ com.fasterxml.woodstox:woodstox-core - CVE-2022-40152
Severity: MODERATE
Affected versions of com.fasterxml.woodstox:woodstox-core are vulnerable to Out-of-bounds Write /
Stack-based Buffer Overflow.

▸▸ Fixed for com.fasterxml.woodstox:woodstox-core at versions: 5.4.0, 6.4.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯ commons-configuration:commons-configuration - CVE-2025-46392
Severity: LOW
Affected versions of commons-configuration:commons-configuration are vulnerable to Uncontrolled
Resource Consumption.

▸▸ Fixed for commons-configuration:commons-configuration at version:
1 <?xml version="1.0" encoding="UTF-8"?>

25 Unreachable Supply Chain Findings

pom.xml
❯❯❯ io.netty:netty-handler - CVE-2025-24970
Severity: HIGH
Affected versions of io.netty:netty-handler are vulnerable to Improper Input Validation. A crafted
packet sent to the SslHandler in Netty may not be validated correctly, leading to a potential native
crash. If an attacker exploits this vulnerability by sending specially crafted SSL packets, it risks
destabilizing the application, particularly in high-performance protocol servers relying on Netty

▸▸ Fixed for io.netty:netty-handler at version: 4.1.118.Final

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-40150
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Uncontrolled Recursion /
Uncontrolled Resource Consumption. Jettison's internal XML/JSON parser may trigger an out-of-memory
condition when processing specially crafted untrusted input, leading to a denial of service attack.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-http2 - CVE-2025-55163
Severity: HIGH
Affected versions of io.grpc:grpc-netty-shaded and io.netty:netty-codec-http2 are vulnerable to
Allocation of Resources Without Limits or Throttling. Netty's HTTP/2 implementation fails to
correctly track active streams when sending RST_STREAM in response to certain malformed control
frames. An attacker can send, for example, WINDOW_UPDATE frames with a zero or overflow increment,
HEADERS/DATA on a half-closed stream, or PRIORITY frames with invalid length to trigger RST_STREAMs;
each reset decrements Netty's concurrent-stream counter even though the request is still processed.
By repeating this on a single connection, the attacker can open an unbounded number of streams,
exhausting CPU and memory and causing a denial of service.

▸▸ Fixed for io.netty:netty-codec-http2 at versions: 4.1.124.Final, 4.2.4.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty-codec-smtp - CVE-2025-59419
Severity: HIGH
Affected versions of io.netty:netty-codec-smtp are vulnerable to Improper Neutralization of CRLF
Sequences ('CRLF Injection') / Improper Neutralization of Special Elements used in an OS Command
('OS Command Injection'). Allows an attacker who can influence SMTP parameters (MAIL FROM, RCPT TO

or HELO) to inject CRLF sequences and thereby craft arbitrary SMTP commands that the client will
send on behalf of trusted hosts.

▸▸ Fixed for io.netty:netty-codec-smtp at versions: 4.1.128.Final, 4.2.7.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ io.netty:netty - CVE-2019-20444
Severity: CRITICAL
io.netty:netty versions before 4.0.0, org.jboss.netty:netty versions before 4.0.0, and
io.netty:netty-codec-http versions >= 4.0.0 before 4.1.44 are vulnerable to Inconsistent
Interpretation Of Http Requests ('Http Request/Response Smuggling').

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.nimbusds:nimbus-jose-jwt - CVE-2023-52428
Severity: HIGH
Affected versions of com.nimbusds:nimbus-jose-jwt are vulnerable to Allocation of Resources Without
Limits or Throttling / Uncontrolled Resource Consumption. A denial-of-service vulnerability exists
in Nimbus JOSE+JWT's PBKDF2-based decryption. An attacker can supply an excessively large iteration
count via the JWE p2c header, triggering extreme resource consumption during decryption.

▸▸ Fixed for com.nimbusds:nimbus-jose-jwt at version: 9.37.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ net.minidev:json-smart - CVE-2023-1370
Severity: HIGH
net.minidev:json-smart versions before 2.4.9 are vulnerable to Uncontrolled Recursion leading to
Denial of Service (DoS) due to a StackOverflowError when parsing a deeply nested JSON array or
object.

▸▸ Fixed for net.minidev:json-smart at version: 2.4.9
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.lz4:lz4-java - CVE-2025-66566
Severity: HIGH
Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and

org.lz4:lz4-pure-java are vulnerable to Insertion of Sensitive Information Into Sent Data. In lz4-java's pure-Java decompressor implementations (safeInstance(), unsafeInstance(), fastestJavaInstance(), fastDecompressor()), insufficient clearing of the output buffer allows a crafted compressed input to copy from uninitialized regions of a reused buffer—potentially leaking residual or sensitive data. The JNI-based safeDecompressor is not affected. Users who reuse buffers without zeroing them before decompression are at risk.

▸▸ Fixed for org.lz4:lz4-java at version:

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ io.netty:netty - CVE-2021-37136

Severity: HIGH

Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable to Uncontrolled Resource Consumption. Netty’s Bzip2Decoder fails to impose an upper limit on the size of decompressed data. This flaw lets attackers supply crafted input that triggers out-of-memory errors, potentially leading to a denial-of-service condition.

▸▸ Fixed for io.netty:netty at version:

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45685

Severity: HIGH

Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The vulnerability involves a stack overflow, enabling attackers to trigger a Denial of Service (DoS) by employing specially crafted JSON data.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2

```
1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯❯ com.squareup.okhttp3:okhttp - CVE-2021-0341

Severity: HIGH

Affected versions of com.squareup.okhttp3:okhttp are vulnerable to Improper Certificate Validation. Improper hostname verification in OkHttp's OkHostnameVerifier.verifyHostName can allow an attacker

to present a certificate for the wrong domain, bypassing TLS checks and causing OkHttp to accept a
malicious cert for an unintended host. This can lead to remote information disclosure without any
user interaction.

▸▸ Fixed for com.squareup.okhttp3:okhttp at version: 4.9.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.code.gson:gson - CVE-2022-25647
Severity: HIGH
Affected versions of com.google.code.gson:gson are vulnerable to Deserialization of Untrusted Data.
Before version 2.8.9, deserializing untrusted data using Java's default serialization (e.g.
`(String) obj.readObject()`) into one of the internal Gson classes `LazilyParsedNumber`,
`LinkedTreeMap` or `LinkedHashTreeMap` can result in a denial of service. These classes are meant to
be serialized and deserialized through Gson's own methods and not through Java's default
serialization. Note that deserializing untrusted data using any method is risky without strict
restrictions on the classes allowed to be deserialized.

▸▸ Fixed for com.google.code.gson:gson at version: 2.8.9
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.assertj:assertj-core - CVE-2026-24400
Severity: HIGH
Affected versions of org.assertj:assertj-core are vulnerable to Improper Restriction of XML External

Entity Reference. An XXE vulnerability exists in AssertJ's
XmlStringPrettyFormatter.toXmlDocument(String), which initializes DocumentBuilderFactory with
default settings (DTD and external entities enabled). If untrusted XML is passed to
isXmlEqualTo(CharSequence) or xmlPrettyFormat(String), an attacker can read local files, perform
SSRF, or trigger DoS via entity expansion.

▸▸ Fixed for org.assertj:assertj-core at version: 3.27.7
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ org.codehaus.jackson:jackson-mapper-asl - CVE-2019-10202
Severity: CRITICAL
Affected versions of org.codehaus.jackson:jackson-mapper-asl are vulnerable to Deserialization of
Untrusted Data. A flaw in jackson-mapper-asl allows untrusted JSON to be deserialized into arbitrary
Java types via ObjectMapper data-binding APIs, so attacker-controlled input can trigger unsafe
object instantiation during deserialization, enabling critical impact when such input reaches these
code paths.Note:This repository is archived.

▸▸ Fixed for org.codehaus.jackson:jackson-mapper-asl at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯❯ com.jamesmurty.utils:java-xmlbuilder - CVE-2014-125087
Severity: CRITICAL
com.jamesmurty.utils:java-xmlbuilder versions before 1.2 are vulnerable to Improper Restriction Of
Xml External Entity Reference. The parser in `XMLBuilder` and `XMLBuilder2` is vulnerable to XML
External Entity (XXE) injection.

▸▸ Fixed for com.jamesmurty.utils:java-xmlbuilder at version: 1.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯ io.netty:netty-codec-http - CVE-2025-58056
Severity: LOW
Affected versions of io.netty:netty-codec-http are vulnerable to Inconsistent Interpretation of HTTP
Requests ('HTTP Request/Response Smuggling'). Netty's HTTP chunked-encoding parser treats a lone LF

in a chunk extension as the end of the size line (instead of requiring CRLF per RFC 9112). If a
front-end proxy instead treats that LF as part of the extension, an attacker can craft a "funky
chunks" payload that the proxy sees as one request but Netty splits into two, enabling standard HTTP
request-smuggling attacks—bypassing access controls and corrupting responses to other clients.

▸▸ Fixed for io.netty:netty-codec-http at versions: 4.1.125.Final, 4.2.5.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.netty:netty - CVE-2021-37137
Severity: HIGH
Affected versions of io.netty:netty, io.netty:netty-codec, and org.jboss.netty:netty are vulnerable
to Uncontrolled Resource Consumption. A lack of input size restrictions in Netty's
SnappyFrameDecoder allows an attacker to send maliciously crafted or oversized compressed frames
(including large skippable chunks) that decompress or buffer to unbounded sizes, resulting in
excessive memory allocations and a denial-of-service.

▸▸ Fixed for io.netty:netty at version:
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.fasterxml.jackson.core:jackson-core - GHSA-72hv-8253-57qq
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core and tools.jackson.core:jackson-core are
vulnerable to Allocation of Resources Without Limits or Throttling. Jackson Core's non-blocking
(async) JSON parser bypasses `StreamReadConstraints.maxNumberLength`, allowing an attacker to submit
JSON containing extremely long numeric literals that the async parser will accept and buffer without
length validation. This can trigger excessive memory allocation in the parser's `TextBuffer` and
potentially severe CPU exhaustion during numeric coercion (e.g., `BigInteger`/`BigDecimal` parsing),
resulting in a Denial of Service in applications using the async parser APIs (such as
reactive/WebFlux pipelines).

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at versions: 2.18.6, 2.21.1, 3.1.0

1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ io.netty:netty-common - CVE-2024-47535
Severity: MODERATE
Affected versions of io.netty:netty-common are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for io.netty:netty-common at version: 4.1.115.Final
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2023-1436
Severity: HIGH
org.codehaus.jettison:jettison versions before 1.5.4 are vulnerable to Uncontrolled Recursion when
constructing a `JSONArray` from a Collection that contains a self-reference in one of its elements.
This leads to a StackOverflowError exception being thrown.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.4
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.codehaus.jettison:jettison - CVE-2022-45693
Severity: HIGH
Affected versions of org.codehaus.jettison:jettison are vulnerable to Out-Of-Bounds Write. The
`org.codehaus.jettison.json.JSONObject` constructor is vulnerable to a `StackOverflowError` when
accepting a HashMap as input. This can lead to Denial of Service (DoS) via crafted string.

▸▸ Fixed for org.codehaus.jettison:jettison at version: 1.5.2
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ commons-beanutils:commons-beanutils - CVE-2025-48734
Severity: HIGH
Affected versions of commons-beanutils:commons-beanutils and org.apache.commons:commons-beanutils2
are vulnerable to Improper Access Control. Apache Commons BeanUtils is vulnerable to improper access
control where attackers can supply untrusted property paths to methods like getProperty, enabling
access to the enums internal declaredClass property. This bypasses protection mechanisms and could
allow remote attackers to gain control of the ClassLoader, potentially leading to arbitrary code

execution.

▸▸ Fixed for commons-beanutils:commons-beanutils at version: 1.11.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ io.airlift:aircompressor - CVE-2025-67721
Severity: HIGH
Affected versions of io.airlift:aircompressor and io.airlift:aircompressor-v3 are vulnerable to
Insertion of Sensitive Information Into Sent Data / Out-of-bounds Read. Aircompressor's Java-based
Snappy and LZ4 decompressors do not properly handle malformed compressed data: a crafted input can
cause bytes from a previously used output buffer to be emitted in the new uncompressed output. In
systems that reuse or don't clear the same decompression buffer across calls, this can leak
sensitive data to an attacker.

▸▸ Fixed for io.airlift:aircompressor at version: 2.0.3
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ org.lz4:lz4-java - CVE-2025-12183
Severity: HIGH
Affected versions of at.yawk.lz4:lz4-java, net.jpountz.lz4:lz4, org.lz4:lz4-java, and
org.lz4:lz4-pure-java are vulnerable to Out-of-bounds Read. A vulnerability in LZ4 Java's
decompression logic allows untrusted compressed input to trigger out-of-bounds memory operations,
leading to JVM crashes (denial of service) or disclosure of adjacent memory.

▸▸ Fixed for org.lz4:lz4-java at version: 1.8.1
1 <?xml version="1.0" encoding="UTF-8"?>

30 Non-blocking Code Findings

src/main/java/org/apache/flink/runtime/blob/BlobClient.java
❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or

'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

91 ┆ socket = new Socket();

src/main/java/org/apache/flink/runtime/blob/BlobUtils.java
❯❯ java.lang.security.audit.crypto.use-of-sha1.use-of-sha1
Detected SHA1 hash algorithm which is considered insecure. SHA1 is not collision resistant and is
therefore not suitable as a cryptographic signature. Instead, use PBKDF2 for password hashing or
SHA256 or SHA512 for other hash function applications.
Details: https://sg.run/bXNp

282 ┆ return MessageDigest.getInstance(HASHING_ALGORITHM);

src/main/java/org/apache/flink/runtime/checkpoint/metadata/MetadataV4Serializer.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

62 ┆ return (CheckpointProperties) new ObjectInputStream(dis).readObject();

src/main/java/org/apache/flink/runtime/entrypoint/component/FileJobGraphRetriever.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

65 ┆ ObjectInputStream obInput = new ObjectInputStream(input)) {

src/main/java/org/apache/flink/runtime/io/network/netty/NettyMessage.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

549 ┆ try (ObjectInputStream ois = new ObjectInputStream(new ByteBufInputStream(buffer))) {

src/main/java/org/apache/flink/runtime/iterative/event/IterationEventWithAggregators.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

93 ┆ Class.forName(classNames[i], true, classResolver)

src/main/java/org/apache/flink/runtime/jobgraph/JobVertex.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

315 ┆ return Class.forName(invokableClassName, true,
cl).asSubclass(TaskInvokable.class);

src/main/java/org/apache/flink/runtime/leaderretrieval/ZooKeeperLeaderRetrievalDriver.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

153 ┆ ObjectInputStream ois = new ObjectInputStream(bais);

src/main/java/org/apache/flink/runtime/net/ConnectionUtils.java
❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or
'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

344 ┆ try (Socket socket = new Socket()) {

src/main/java/org/apache/flink/runtime/operators/util/TaskConfig.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

341 ┆ return Class.forName(className).asSubclass(pdClazz);
⋮┆----------
398 ┆ Class.forName(className, true, cl).asSubclass(superClass);

⋮┆----------
638┆ clazz = Class.forName(className, true, cl).asSubclass(DataDistribution.class);
⋮┆----------
806┆ return Class.forName(className).asSubclass(clazz);
⋮┆----------
1228┆ Class.forName(className, true, cl).asSubclass(superClass);
⋮┆----------
1284┆ Class.forName(className, true, cl).asSubclass(superClass);

src/main/java/org/apache/flink/runtime/rest/RestClient.java
❯❯
java.lang.security.audit.active-debug-code-printstacktrace.active-debug-code-printstacktrace
Possible active debug code detected. Deploying an application with debug code can create unintended
entry points or expose sensitive information.
Details: https://sg.run/4K8z

261┆ t.printStackTrace();

src/main/java/org/apache/flink/runtime/rest/handler/job/JobSubmitHandler.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

143┆ try (ObjectInputStream objectIn =
144┆ new ObjectInputStream(
145┆ executionPlanFile.getFileSystem().open(executionPlanFile))) {

src/main/java/org/apache/flink/runtime/scheduler/adaptivebatch/StreamGraphOptimizer.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack

vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
94 ┆ Class.forName(strategyClassName, false, userClassLoader)
```

src/main/java/org/apache/flink/runtime/state/CheckpointStorageLoader.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
108 ┆ Class.forName(storageName, false, classLoader)
```

src/main/java/org/apache/flink/runtime/state/StateBackendLoader.java
❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection
If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
151 ┆ Class.forName(factoryClassName, false, classLoader)
  ⋮ ┆----------------------------------------
370 ┆ Class.forName(className, false, classLoader)
```

src/main/java/org/apache/flink/runtime/state/TaskLocalStateStoreImpl.java
❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that

the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

```
268 ┆ try (ObjectInputStream ois =
269 ┆         new ObjectInputStream(new FileInputStream(taskStateSnapshotFile))) {
```

src/main/java/org/apache/flink/runtime/taskexecutor/slot/FileSlotAllocationSnapshotPersistenceService.java

❯❯ java.lang.security.audit.object-deserialization.object-deserialization

Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

```
122 ┆ try (ObjectInputStream ois =
123 ┆         new ObjectInputStream(new FileInputStream(allocationFile))) {
```

src/main/java/org/apache/flink/runtime/taskmanager/Task.java

❯❯ java.lang.security.audit.unsafe-reflection.unsafe-reflection

If an attacker can supply values that the application then uses to determine which class to
instantiate or which method to invoke, the potential exists for the attacker to create control flow
paths through the application that were not intended by the application developers. This attack
vector may allow the attacker to bypass authentication or access control checks or otherwise cause
the application to behave in an unexpected manner.
Details: https://sg.run/R8X8

```
1623 ┆ Class.forName(className, true, classLoader).asSubclass(TaskInvokable.class);
```

src/main/java/org/apache/flink/runtime/util/ZooKeeperUtils.java

❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

```
506 ┆ try (final ObjectInputStream ois = new ObjectInputStream(bais)) {
```

src/main/java/org/apache/flink/streaming/api/functions/sink/legacy/SocketClientSink.java
❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or
'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

```
278 ┆ client = new Socket(hostName, port);
```

src/main/java/org/apache/flink/streaming/api/functions/source/legacy/SocketTextStreamFunction.java
❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or
'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

```
103 ┆ try (Socket socket = new Socket()) {
```

src/main/java/org/apache/flink/streaming/api/operators/collect/CollectSinkFunction.java
❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or

'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

379 ┆ this.serverSocket = new ServerSocket(getPort(), 0, getBindAddress());

src/main/java/org/apache/flink/streaming/api/operators/collect/CollectSinkOperatorCoordinator.java

❯❯ java.lang.security.audit.object-deserialization.object-deserialization
Found object deserialization using ObjectInputStream. Deserializing entire Java objects is dangerous
because malicious actors can create Java object streams with unintended consequences. Ensure that
the objects being deserialized are not user-controlled. If this must be done, consider using HMACs
to sign the data stream to make sure it is not tampered with, or consider only transmitting object
fields and populating a new object.
Details: https://sg.run/Ek0A

242 ┆ ObjectInputStream ois = new ObjectInputStream(bais);

src/main/java/org/apache/flink/streaming/api/operators/collect/SocketConnection.java

❯❯ java.lang.security.audit.crypto.unencrypted-socket.unencrypted-socket
Detected use of a Java socket that is not encrypted. As a result, the traffic could be read by an
attacker intercepting the network traffic. Use an SSLSocket created by 'SSLSocketFactory' or
'SSLServerSocketFactory' instead.
Details: https://sg.run/W8zA

44 ┆ final Socket newSocket = new Socket();

```
┌──────────────┐
│ Scan Summary │
└──────────────┘
```

✅ CI scan completed successfully.
• Findings: 91 (0 blocking)
• Rules run: 116516
• Targets scanned: 3161
• Parsed lines: ~100.0%
• Scan skipped:

- Files larger than files 1.0 MB: 3
- Files matching .semgrepignore patterns: 2181

• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/flink&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/flink&ref=semgrep-uc
No blocking findings so exiting with code 0

Reachable

CVE-2019-10172 CVE-2025-55163 CVE-2021-27568 CVE-2014-3643	CVE-2021-22569 CVE-2025-12183 CVE-2025-66566 CVE-2025-12183	CVE-2025-66566 CVE-2025-12183 CVE-2025-66566

Undetermined

CVE-2024-23944 CVE-2021-37533 CVE-2025-58057 CVE-2021-21409 CVE-2025-68161 CVE-2025-48924 CVE-2019-20445 CVE-2025-67735	CVE-2020-8908 CVE-2024-23454 CVE-2021-21290 CVE-2022-3171 CVE-2021-21295 CVE-2022-40149 CVE-2024-29025 CVE-2023-3635	CVE-2022-23437 CVE-2018-10237 CVE-2023-2976 CVE-2025-53864 CVE-2021-43797 CVE-2025-25193 CVE-2022-40152 CVE-2025-46392

Unreachable

CVE-2025-24970 CVE-2022-40150 CVE-2025-55163 CVE-2025-59419 CVE-2019-20444 CVE-2023-52428 CVE-2023-1370 CVE-2025-66566	CVE-2021-37136 CVE-2022-45685 CVE-2021-0341 CVE-2024-7254 CVE-2022-25647 CVE-2026-24400 CVE-2019-10202 CVE-2014-125087	CVE-2025-58056 CVE-2021-37137 GHSA-72hv-8253-57qq CVE-2024-47535 CVE-2023-1436 CVE-2022-45693 CVE-2025-48734 CVE-2025-67721 CVE-2025-12183

Graphhopper

```
┌──────────────────────────────────────────────────────────┐
│ 3 Reachable Supply Chain Findings │
└──────────────────────────────────────────────────────────┘
```

pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2022-3509
Severity: HIGH
protobuf-java and protobuf-javalite 3.21.x before 3.21.7, 3.20.x before 3.20.3, 3.19.x before
3.19.6, 3.16.x before 3.16.3 are vulnerable to a Denial of Service (DoS) attack through specially
crafted input messages. It is recommended to upgrade protobuf-java and protobuf-javalite 3.21.x to
3.21.7, 3.20.x to 3.20.3, 3.19.x to 3.19.6, and 3.16.x to 3.16.3.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.3, 3.19.6, 3.20.3, 3.21.7
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.protobuf:protobuf-java - CVE-2021-22569
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java and com.google.protobuf:protobuf-kotlin are
vulnerable to Incorrect Behavior Order. Parsing of unknown fields in the Java Protobuf runtime can
be abused by a crafted binary payload (~800 KB) to trigger excessive short-lived object allocations,
causing repeated GC pauses and prolonged parsing times, resulting in a Denial of Service.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.1, 3.18.2, 3.19.2
1 <?xml version="1.0" encoding="UTF-8"?>

src/main/java/com/graphhopper/reader/osm/pbf/PbfBlobDecoder.java with lockfile pom.xml
❯❯❯ com.google.protobuf:protobuf-java - CVE-2024-7254
Severity: HIGH
Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to

Improper Input Validation / Out-of-bounds Write / Uncontrolled Resource Consumption. When parsing
unknown fields in the Protobuf Java Lite and Full library, a maliciously crafted message can cause a
StackOverflow error and lead to a program crash.

```
▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.25.5, 4.27.5, 4.28.2
 5 import com.google.protobuf.InvalidProtocolBufferException;
```

5 Undetermined Supply Chain Findings

pom.xml

❯❯ ch.qos.logback:logback-core - CVE-2024-12798

Severity: MODERATE

Affected versions of ch.qos.logback:logback-core are vulnerable to Improper Neutralization of
Special Elements used in an Expression Language Statement ('Expression Language Injection').

```
▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.15, 1.5.13
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ ch.qos.logback:logback-core - CVE-2024-12801

Severity: LOW

Affected versions of ch.qos.logback:logback-core are vulnerable to Server-Side Request Forgery
(SSRF).

```
▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.15, 1.5.13
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯ ch.qos.logback:logback-core - CVE-2026-1225

Severity: LOW

Affected versions of ch.qos.logback:logback-core are vulnerable to Improper Input Validation.

```
▸▸ Fixed for ch.qos.logback:logback-core at version: 1.5.25
 1 <?xml version="1.0" encoding="UTF-8"?>
```

❯❯ com.google.protobuf:protobuf-java - CVE-2022-3171

Severity: MODERATE

Affected versions of com.google.protobuf:protobuf-java, com.google.protobuf:protobuf-javalite,
com.google.protobuf:protobuf-kotlin, and com.google.protobuf:protobuf-kotlin-lite are vulnerable to
Improper Input Validation.

▸▸ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.3, 3.19.6, 3.20.3, 3.21.7
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯ ch.qos.logback:logback-core - CVE-2025-11226
Severity: MODERATE
Affected versions of ch.qos.logback:logback-core are vulnerable to Improper Input Validation.

▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.16, 1.5.19
1 <?xml version="1.0" encoding="UTF-8"?>

7 Unreachable Supply Chain Findings

pom.xml
❯❯❯ commons-io:commons-io - CVE-2024-47554
Severity: HIGH
Affected versions of commons-io:commons-io are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for commons-io:commons-io at version: 2.14.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ ch.qos.logback:logback-classic - CVE-2023-6378
Severity: HIGH
Affected versions of ch.qos.logback:logback-core and ch.qos.logback:logback-classic are vulnerable
to Uncontrolled Resource Consumption. A serialization vulnerability in the logback reciever
component part of lockback allows an attacker to mount a Denial-Of-Service attack by sending
poisoned data.

▸▸ Fixed for ch.qos.logback:logback-classic at versions: 1.2.13, 1.3.12, 1.4.12
1 <?xml version="1.0" encoding="UTF-8"?>

⋮ ┆ ----------
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.fasterxml.jackson.core:jackson-core - GHSA-72hv-8253-57qq
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core and tools.jackson.core:jackson-core are
vulnerable to Allocation of Resources Without Limits or Throttling. Jackson Core's non-blocking
(async) JSON parser bypasses `StreamReadConstraints.maxNumberLength`, allowing an attacker to submit
JSON containing extremely long numeric literals that the async parser will accept and buffer without
length validation. This can trigger excessive memory allocation in the parser's `TextBuffer` and
potentially severe CPU exhaustion during numeric coercion (e.g., `BigInteger`/`BigDecimal` parsing),
resulting in a Denial of Service in applications using the async parser APIs (such as
reactive/WebFlux pipelines).

▸▸ ┆ Fixed for com.fasterxml.jackson.core:jackson-core at versions: 2.18.6, 2.21.1, 3.1.0
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.google.protobuf:protobuf-java - CVE-2022-3510
Severity: HIGH
A Affected versions of com.google.protobuf:protobuf-java and com.google.protobuf:protobuf-javalite
are vulnerable to Uncontrolled Resource Consumption. The vulnerability stems from a parsing issue in
the Message-Type Extensions, affecting certain package versions and allowing for Denial of Service
(DoS) attacks through inputs containing multiple instances of non-repeated embedded messages with
repeated or unknown fields; exploiting it triggers conversions between mutable and immutable forms,
potentially leading to extended garbage collection pauses.

▸▸ ┆ Fixed for com.google.protobuf:protobuf-java at versions: 3.16.3, 3.19.6, 3.20.3, 3.21.7
1 ┆ <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ com.fasterxml.jackson.core:jackson-core - CVE-2025-52999
Severity: HIGH

Affected versions of com.fasterxml.jackson.core:jackson-core are vulnerable to Stack-based Buffer
Overflow. Jackson-core is vulnerable to a denial-of-service attack where an attacker provides a
deeply nested input document, triggering a Stackoverflow error during parsing. This flaw can be
exploited when processing untrusted data, potentially undermining application availability.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at version: 2.15.0
1 <?xml version="1.0" encoding="UTF-8"?>

❯❯❯ ch.qos.logback:logback-core - CVE-2023-6481
Severity: HIGH
Affected versions of ch.qos.logback:logback-core are vulnerable to Uncontrolled Resource
Consumption. The vulnerability lies in Uncontrolled Resource Consumption ('Resource Exhaustion')
through the logback receiver component, enabling attackers to initiate a denial-of-service attack by
transmitting malicious data.

▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.2.13, 1.3.14, 1.4.14
1 <?xml version="1.0" encoding="UTF-8"?>

┌──────────────┐
│ Scan Summary │
└──────────────┘

✅ CI scan completed successfully.
• Findings: 15 (0 blocking)
• Rules run: 116506
• Targets scanned: 625
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 13
  ◦ Files matching .semgrepignore patterns: 284
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/graphhopper&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/graphhopper&ref=semgrep-uc
No blocking findings so exiting with code 0

Poi-tl

```
┌──────────────────────────────────────────────────┐
│ 2 Reachable Supply Chain Findings │
└──────────────────────────────────────────────────┘

  src/main/java/com/deepoove/poi/render/compute/SpELRenderDataCompute.java with lockfile
 pom.xml
  ❯❯❱ org.springframework:spring-expression - CVE-2023-20863
        Severity: HIGH
        org.springframework:spring-core versions before 5.2.24.RELEASE, >= 5.3.0 before
5.3.27, >= 6.0.0
        before 6.0.8 are vulnerable are vulnerable to denial-of-service (DoS) via specially crafted
Spring
        Expression Language (SpEL) expression due to Improper Neutralization Of Special
Elements Used In An
        Expression Language Statement ('Expression Language Injection').

        ▶▶┆ Fixed for org.springframework:spring-expression at versions: 5.2.24.RELEASE,
5.3.27, 6.0.8
         65┆ Object val = parser.parseExpression(el).getValue(envContext);
          ⋮┆----------------------------------------
         73┆ return parser.parseExpression(el).getValue(context);


┌──────────────────────────────────────────────────┐
│ 15 Undetermined Supply Chain Findings │
└──────────────────────────────────────────────────┘

  pom.xml
  ❯❱ ch.qos.logback:logback-core - CVE-2024-12798
        Severity: MODERATE
        Affected versions of ch.qos.logback:logback-core are vulnerable to Improper
Neutralization of
```

Special Elements used in an Expression Language Statement ('Expression Language Injection').

```
▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.15, 1.5.13
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯❯ org.apache.commons:commons-lang3 - CVE-2025-48924
Severity: MODERATE
Affected versions of commons-lang:commons-lang and org.apache.commons:commons-lang3 are vulnerable to Uncontrolled Recursion.

```
▸▸ Fixed for org.apache.commons:commons-lang3 at version: 3.18.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯ ch.qos.logback:logback-core - CVE-2024-12801
Severity: LOW
Affected versions of ch.qos.logback:logback-core are vulnerable to Server-Side Request Forgery (SSRF).

```
▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.15, 1.5.13
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯ com.google.guava:guava - CVE-2020-8908
Severity: LOW
Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File With Insecure Permissions / Exposure of Sensitive Information to an Unauthorized Actor / Improper Handling of Alternate Encoding / Incorrect Permission Assignment for Critical Resource.

```
▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯❯ org.yaml:snakeyaml - CVE-2022-38752
Severity: MODERATE
Affected versions of org.yaml:snakeyaml are vulnerable to Out-of-bounds Write / Stack-based Buffer Overflow.

```
▸▸ Fixed for org.yaml:snakeyaml at version: 1.32
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❱ ch.qos.logback:logback-core - CVE-2026-1225
Severity: LOW
Affected versions of ch.qos.logback:logback-core are vulnerable to Improper Input Validation.

▸▸ Fixed for ch.qos.logback:logback-core at version: 1.5.25
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❱❱ org.yaml:snakeyaml - CVE-2022-41854
Severity: MODERATE
Affected versions of org.yaml:snakeyaml are vulnerable to Out-of-bounds Write / Stack-based Buffer
Overflow.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.32
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❱❱ org.yaml:snakeyaml - CVE-2022-38750
Severity: MODERATE
Affected versions of org.yaml:snakeyaml are vulnerable to Out-of-bounds Write / Stack-based Buffer
Overflow.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.31
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❱❱ org.yaml:snakeyaml - CVE-2022-38749
Severity: MODERATE
Affected versions of be.cylab:snakeyaml, com.alipay.sofa.acts:acts-common-util,
io.prometheus.jmx:jmx_prometheus_httpserver, io.prometheus.jmx:jmx_prometheus_httpserver_java6,
org.testifyproject.external:external-snakeyaml, org.yaml:snakeyaml, and
pl.droidsonroids.yaml:snakeyaml are vulnerable to Out-of-bounds Write / Stack-based Buffer Overflow.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.31
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❱❱ org.yaml:snakeyaml - CVE-2022-38751
Severity: MODERATE
Affected versions of org.yaml:snakeyaml are vulnerable to Out-of-bounds Write / Stack-based Buffer
Overflow.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.31
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ com.fasterxml.jackson.core:jackson-core - CVE-2025-49128
Severity: MODERATE
Affected versions of com.fasterxml.jackson.core:jackson-core are vulnerable to Generation of Error
Message Containing Sensitive Information.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at version: 2.13.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ org.apache.poi:poi-ooxml - CVE-2025-31672
Severity: MODERATE
Affected versions of org.apache.poi:poi-ooxml are vulnerable to Improper Input Validation.

▸▸ Fixed for org.apache.poi:poi-ooxml at version: 5.4.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ com.google.guava:guava - CVE-2023-2976
Severity: MODERATE
Affected versions of com.google.guava:guava are vulnerable to Creation of Temporary File in
Directory with Insecure Permissions / Files or Directories Accessible to External Parties.

▸▸ Fixed for com.google.guava:guava at version: 32.0.0-android
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ ch.qos.logback:logback-core - CVE-2025-11226
Severity: MODERATE
Affected versions of ch.qos.logback:logback-core are vulnerable to Improper Input Validation.

▸▸ Fixed for ch.qos.logback:logback-core at versions: 1.3.16, 1.5.19
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ org.springframework:spring-expression - CVE-2024-38808
Severity: MODERATE
Affected versions of org.springframework:spring-expression are vulnerable to Allocation of Resources
Without Limits or Throttling.

▸▸ Fixed for org.springframework:spring-expression at version: 5.3.39
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

15 Unreachable Supply Chain Findings

pom.xml

❯❯❯ com.fasterxml.jackson.core:jackson-databind - CVE-2020-36518

Severity: HIGH

Affected versions of com.fasterxml.jackson.core:jackson-databind are vulnerable to Out-of-bounds Write. This vulnerability in Jackson Databind can allow attackers to manipulate memory, potentially leading to arbitrary code execution or application crashes.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-databind at versions: 2.12.6.1, 2.13.2.1

```
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯❯❯ org.springframework:spring-core - CVE-2025-41249

Severity: HIGH

Affected versions of org.springframework:spring-core are vulnerable to Improper Authorization / Incorrect Authorization. Spring's annotation resolution can fail on methods in type hierarchies with parameterized super-types and unbounded generics, causing annotations used for authorization (e.g. @PreAuthorize, @Secured, @Transactional) to be invisible on concrete implementations. In apps using Spring Security's @EnableMethodSecurity, security annotations declared on generic superclasses or interfaces may be ignored on subclasses, potentially allowing unauthorized access.

▸▸ Fixed for org.springframework:spring-core at version: 6.2.11

```
1 <project xmlns="http://maven.apache.org/POM/4.0.0"
```

❯❯❯ com.fasterxml.jackson.core:jackson-databind - CVE-2020-25649

Severity: HIGH

Affected versions of com.fasterxml.jackson.core:jackson-databind are vulnerable to Improper Restriction of XML External Entity Reference. Jackson-databind's XML DOM deserializer (`DOMDeserializer`) fails to fully disable external entity expansion on all XML providers. If an

attacker supplies crafted XML and a provider that permits entity expansion (e.g. Xerces) is on the
classpath, deserialization will resolve external entities, enabling XXE attacks that can compromise
data integrity or leak sensitive information.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-databind at versions: 2.10.5.1, 2.6.7.4, 2.9.10.7
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ org.apache.commons:commons-compress - CVE-2024-26308
Severity: MODERATE
Affected versions of org.apache.commons:commons-compress are vulnerable to Resource Exhaustion.
Specifically, it is Allocation of Resources Without Limits or Throttling. Excessive consumption of
resources can lead to DoS.

▸▸ Fixed for org.apache.commons:commons-compress at version: 1.26.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ commons-io:commons-io - CVE-2024-47554
Severity: HIGH
Affected versions of commons-io:commons-io are vulnerable to Uncontrolled Resource Consumption.

▸▸ Fixed for commons-io:commons-io at version: 2.14.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ com.fasterxml.jackson.core:jackson-databind - CVE-2021-46877
Severity: HIGH
com.fasterxml.jackson.core:jackson-databind versions >= 2.13.0 before 2.13.1, >= 2.10.0 before
2.12.6 are vulnerable to Denial of Service, but only when using JDK serialization to serialize /
deserialize JsonNode values. If an attacker can provide their own input to the deserialization
process, they can make the program run out of heap memory.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-databind at versions: 2.12.6, 2.13.1
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ org.yaml:snakeyaml - CVE-2022-1471
Severity: HIGH

snakeyaml <= 1.33 is vulnerable to unsafe deserialization, which can lead to Remote Code Execution
(RCE) if deserializing untrusted data using Constructor(). It is recommended to upgrade snakeyaml to
2.0 or greater and use SafeConstructor() instead of Constructor().

▸▸ Fixed for org.yaml:snakeyaml at version: 2.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ org.apache.commons:commons-compress - CVE-2024-25710
Severity: MODERATE
Affected versions of org.apache.commons:commons-compress are vulnerable to Loop With Unreachable
Exit Condition ('Infinite Loop'). The vulnerability in Apache Commons Compress, involves a loop with
an unreachable exit condition when reading a corrupted DUMP archive file.

▸▸ Fixed for org.apache.commons:commons-compress at version: 1.26.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ org.yaml:snakeyaml - CVE-2017-18640
Severity: HIGH
Affected versions of org.yaml:snakeyaml are vulnerable to Improper Restriction of Recursive Entity
References in DTDs ('XML Entity Expansion'). This vulnerability allows a crafted YAML document with
recursive or nested entity references to trigger excessive resource usage during parsing,
potentially leading to a denial of service (DoS) condition.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.26
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ org.yaml:snakeyaml - CVE-2022-25857
Severity: HIGH
Affected versions of org.yaml:snakeyaml are vulnerable to Improper Restriction of Recursive Entity
References in DTDs ('XML Entity Expansion') / Uncontrolled Resource Consumption. SnakeYAML is
vulnerable to a Denial of Service attack when processing deeply nested YAML collections. Without a
nested depth limit, a maliciously crafted YAML input could overwhelm the parser with excessive
nesting, leading to significant resource exhaustion and potential service disruption.

▸▸ Fixed for org.yaml:snakeyaml at version: 1.31
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯ org.springframework:spring-expression - CVE-2023-20861
Severity: MODERATE
Affected versions of org.springframework:spring-expression are vulnerable to Improper Neutralization
of Special Elements used in an Expression Language Statement ('Expression Language Injection') /
Uncontrolled Resource Consumption. A remote attacker can trigger a denial-of-service condition by
causing the Spring Expression Language engine to perform excessive computation or memory allocation
when evaluating a maliciously constructed input.

▸▸ Fixed for org.springframework:spring-expression at versions: 5.2.23.RELEASE, 5.3.26, 6.0.7
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ com.fasterxml.jackson.core:jackson-databind - CVE-2022-42003
Severity: HIGH
In FasterXML jackson-databind before 2.12.7.1 and in 2.13.x before 2.13.4.1 resource exhaustion can
occur because of a lack of a check in primitive value deserializers to avoid deep wrapper array
nesting, when the UNWRAP_SINGLE_VALUE_ARRAYS feature is enabled. This was patched in 2.12.7.1,
2.13.4.1, and 2.14.0.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-databind at versions: 2.12.7.1, 2.13.4.2
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ com.fasterxml.jackson.core:jackson-core - GHSA-72hv-8253-57qq
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core and tools.jackson.core:jackson-core are
vulnerable to Allocation of Resources Without Limits or Throttling. Jackson Core's non-blocking
(async) JSON parser bypasses `StreamReadConstraints.maxNumberLength`, allowing an attacker to submit
JSON containing extremely long numeric literals that the async parser will accept and buffer without

length validation. This can trigger excessive memory allocation in the parser's `TextBuffer` and
potentially severe CPU exhaustion during numeric coercion (e.g., `BigInteger`/`BigDecimal` parsing),
resulting in a Denial of Service in applications using the async parser APIs (such as
reactive/WebFlux pipelines).

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at versions: 2.18.6, 2.21.1, 3.1.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ com.fasterxml.jackson.core:jackson-core - CVE-2025-52999
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-core are vulnerable to Stack-based Buffer
Overflow. Jackson-core is vulnerable to a denial-of-service attack where an attacker provides a
deeply nested input document, triggering a Stackoverflow error during parsing. This flaw can be
exploited when processing untrusted data, potentially undermining application availability.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-core at version: 2.15.0
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

❯❯❯ com.fasterxml.jackson.core:jackson-databind - CVE-2022-42004
Severity: HIGH
Affected versions of com.fasterxml.jackson.core:jackson-databind are vulnerable to Deserialization
of Untrusted Data / Uncontrolled Resource Consumption. In FasterXML jackson-databind versions before
2.12.7.1 and 2.13.x before 2.13.4, enabling the `UNWRAP_SINGLE_VALUE_ARRAYS` feature allows a
specially crafted deeply nested array to exhaust system resources during deserialization. This can
lead to application crashes or Denial of Service (DoS), as unvalidated input can exploit the lack of
checks in the deserialization process.

▸▸ Fixed for com.fasterxml.jackson.core:jackson-databind at versions: 2.12.7.1, 2.13.4
1 <project xmlns="http://maven.apache.org/POM/4.0.0"

3 Non-blocking Code Findings

src/main/java/com/deepoove/poi/render/compute/SpELRenderDataCompute.java
❯❯ java.spring.security.audit.spel-injection.spel-injection
A Spring expression is built with a dynamic value. The source of the value(s) should be verified to
avoid that unfiltered values fall into this risky code evaluation.
Details: https://sg.run/XBp4

```
60 @Override
61 public Object compute(String el) {
62     try {
63         if (null != envContext && !el.contains("#this")) {
64             try {
65                 Object val = parser.parseExpression(el).getValue(envContext);
66                 if (null != val) {
67                     return val;
68                 }
69             } catch (Exception e) {
```

[hid 9 additional lines, adjust with --max-lines-per-finding]

src/main/java/com/deepoove/poi/render/processor/DrawingSupport.java
❯❯ java.lang.security.audit.active-debug-code-printstacktrace.active-debug-code-printstacktrace
Possible active debug code detected. Deploying an application with debug code can create unintended
entry points or expose sensitive information.
Details: https://sg.run/4K8z

```
122 e.printStackTrace();
```

src/main/java/com/deepoove/poi/xwpf/XWPFParagraphWrapper.java
❯❯ java.lang.security.audit.crypto.weak-random.weak-random
Detected use of the functions `Math.random()` or `java.util.Random()`. These are both not
cryptographically strong random number generators (RNGs). If you are using these RNGs to create
passwords or secret tokens, use `java.security.SecureRandom` instead.
Details: https://sg.run/NwBp

```
151 start.setId(BigInteger.valueOf(500 + new Random().nextInt(50000)));
```

Scan Summary

└──────────────────────┘
✅ CI scan completed successfully.
• Findings: 35 (0 blocking)
• Rules run: 116517
• Targets scanned: 246
• Parsed lines: ~100.0%
• Scan skipped:
  ◦ Files larger than files 1.0 MB: 5
  ◦ Files matching .semgrepignore patterns: 453
• Scan was limited to files tracked by git
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
CI scan completed successfully.
  View results in Semgrep Cloud Platform:

https://semgrep.dev/orgs/tulipgamage-personal-org/findings?repo=local_scan/poi-tl&ref=semgrep-uc

https://semgrep.dev/orgs/tulipgamage-personal-org/supply-chain/vulnerabilities?repo=local_scan/poi-tl&ref=semgrep-uc
  No blocking findings so exiting with code 0